

Bộ Giáo Dục Và Đào Tạo
Trường Đại Học Ngoại Ngữ - Tin Học Thành Phố Hồ Chí Minh
Khoa Công Nghệ Thông Tin



MÔN HỌC : BẢO MẬT NGƯỜI DÙNG CUỐI

ĐỀ TÀI :

Giáo Viên Hướng Dẫn : Ths. Đỗ Phi Hưng

Thành Viên :

1. Phan Tất Thắng – MSSV:22DH113428
2. Phạm Quốc Huy – MSSV:22DH111305
3. Phùng Ngọc Bách – MSSV: 22DH114463

Tp. Hồ chí minh, Ngày 24 tháng 07 năm 2025

Lời cảm ơn

Kính gửi thầy Đỗ Phi Hưng,

Chúng em xin gửi lời cảm ơn chân thành đến thầy vì đã tận tâm giảng dạy môn Bảo Mật Người Dùng Cuối trong suốt học kỳ vừa qua.

Đây là một môn học đầy mới mẻ và hữu ích. Nhờ phương pháp giảng dạy dễ hiểu, sinh động cùng sự nhiệt tình của thầy, chúng em đã tiếp thu được nhiều kiến thức bổ ích và hiểu rõ hơn về tầm quan trọng của bảo mật trong môi trường người dùng cuối.

Chúng em rất trân trọng sự tận tâm và hỗ trợ của thầy trong suốt quá trình học. Kính chúc thầy luôn mạnh khỏe, hạnh phúc và tiếp tục truyền cảm hứng cho nhiều thế hệ sinh viên.

Trân trọng cảm ơn thầy!

Mục lục

Lời cảm ơn	2
Mục lục	3
Nhận xét của giảng viên.....	5
Danh mục hình ảnh	6
Danh mục bảng	7
CHƯƠNG I CƠ SỞ LÝ THUYẾT	8
1. Tổng quan về bảo mật người dùng cuối	8
1.1 Giới thiệu	8
1.2 Khái niệm	8
1.3 Các môi đe dọa phổ biến	8
1.4 Vai trò của bảo mật ở phía người dùng	9
1.5 Công nghệ hỗ trợ bảo mật người dùng cuối	9
1.5 Vai trò của người dùng cuối trong an ninh mạng	9
2. Kiến trúc mạng LAN cơ bản (Client – Server).....	9
2.1 Các thành phần trong hệ thống.....	9
2.2 Các dịch vụ thường có.....	10
2.3 Các giao thức mạng thường dùng.....	11
3. Giới thiệu các giải pháp IDS/IPS.....	11
3.1 Khái niệm IDS và IPS	11
3.2 Nguyên lý hoạt động	11
3.3 Ví dụ các công cụ IDS/IPS phổ biến	11
3.4 Phân loại IDS/IPS.....	12
3.5 Bản so sánh.....	14
3.6 Các phương pháp phát hiện	14

4.	Giới thiệu các giải pháp System Endpoint.....	15
4.1	Khái niệm Endpoint Protection	15
4.2	Vai trò và tính năng	15
4.3	Các phần mềm phổ biến	15
4.4	Các loại endpoint cần bảo vệ.....	16
4.5	Các mối đe dọa cụ thể với endpoint	16
5.	Tổng kết chương	16
	CHƯƠNG II LÊN KẾ HOẠCH TRIỂN KHAI	17
1.	Mục tiêu	17
2.	Phạm vi	17
3.	Tài nguyên và nhân sự	17
4.	Thiết kế kiến trúc mạng	18
5.	Chiến lược cấu hình	19
6.	Nguyên lý hoạt động.....	19
	CHƯƠNG III TRIỂN KHAI	22
1.	Sơ đồ triển khai.....	22
2.	Cấu hình cơ bản cho pfsense	23
3.	Quản lí người dùng cuối	26
4.	Viết Rule Snort	35
5.	Viết Rule cho Pfsense từ Snort để kiểm soát mạng các thiết bị trong mạng LAN	36
6.	Cài đặt system endpoint (hip ossec)	37
7.	Cài đặt demo 3 case tấn công:	45
7.1	Tấn công thu thập thông tin và bruteforce ssh	45
7.2	Demo tấn công sql injection	52
7.3	Demo tan cong ddos web	56
	CHƯƠNG V TÀI LIỆU THAM KHẢO	66

Nhận xét của giảng viên

Danh mục hình ảnh

Hình 1. Hệ thống mạng cơ bản.....	10
Hình 2. Sơ đồ mạng.....	18
Hình 3. Sơ đồ triển khai	22
Hình 4. Cấu hình ban đầu cho Pfsense	23
Hình 5. Giao diện cấu hình và quản lý bằng dòng lệnh đã được setup IP và ping ra ngoài Internet.....	24
Hình 6. Giao diện cấu hình và quản lý bằng GUI thông qua địa chỉ IP default gateway và port.....	25
Hình 7. Định nghĩa các aliases để phù hợp với các phân cấp vlan.....	26
Hình 8. Tạo các rules cho Vlan10, không bị giới hạn	27
Hình 9. Tạo các rules cho Vlan20, không bị giới hạn	28
Hình 10. Tạo các rules cho Vlan30, không bị giới hạn	29
Hình 11. Tạo các rule cho vlan 40 không cho ra internet.....	30
Hình 12. Người dùng vlan10 truy cập không giới hạn thành công	31
Hình 13. Người dùng vlan20,30 truy cập trang facebook không thành công.....	32
Hình 14. Người dùng vlan20,30 truy cập trang bongda.com.vn không thành công.....	33
Hình 15. Người dùng vlan40 không cho ra internet thành công	34
Hình 16. Tích chọn các rule đã tải về từ snort community để tích hợp phát hiện ngăn chặn cho cổng wan.....	35
Hình 17. Rules cho mạng LAN để kiểm tra mạng LAN đang truy	36

Danh mục bảng

Bảng 1. Bảng so sánh IDS và IPS	14
---------------------------------------	----

CHƯƠNG I CƠ SỞ LÝ THUYẾT

1. Tổng quan về bảo mật người dùng cuối

1.1 Giới thiệu

Trong bối cảnh các cuộc tấn công mạng ngày càng tinh vi và phức tạp, việc bảo vệ hệ thống mạng không còn là lựa chọn mà trở thành yêu cầu bắt buộc đối với mọi tổ chức, doanh nghiệp. Đặc biệt, điểm yếu lớn nhất trong hệ thống mạng thường nằm ở các thiết bị đầu cuối – nơi người dùng truy cập và xử lý dữ liệu trực tiếp. Chính vì vậy, việc xây dựng một hệ thống mạng bảo mật Endpoint trở nên cấp thiết, giúp ngăn chặn và giảm thiểu rủi ro từ những cuộc tấn công có thể phát sinh từ người dùng cuối.

Mục tiêu của đề án là nghiên cứu, thiết kế và triển khai một hệ thống mạng tích hợp các giải pháp bảo mật hiện đại, bao gồm hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS) và các giải pháp bảo mật thiết bị đầu cuối (System Endpoint). Hệ thống này không chỉ giúp giám sát, phát hiện các hành vi bất thường mà còn có khả năng phản ứng, xử lý mối đe dọa kịp thời, góp phần nâng cao mức độ an toàn thông tin cho toàn hệ thống.

Lý do chọn đề tài xuất phát từ nhu cầu thực tế tại các môi trường doanh nghiệp, cơ quan, trường học, nơi mà nhân viên, sinh viên sử dụng thiết bị cá nhân hoặc công cộng để truy cập tài nguyên chung. Trong môi trường này, nếu không có giải pháp bảo vệ các Endpoint thì một thiết bị bị nhiễm mã độc có thể trở thành cầu nối cho hacker xâm nhập vào toàn bộ hệ thống mạng nội bộ. Bên cạnh đó, đề tài này cũng mang lại cơ hội để nhóm sinh viên rèn luyện các kỹ năng triển khai thực tế, làm quen với các công cụ chuyên nghiệp trong lĩnh vực bảo mật.

1.2 Khái niệm

Bảo mật người dùng cuối (End-User Security) là tập hợp các biện pháp nhằm bảo vệ thiết bị đầu cuối (máy tính cá nhân, laptop, smartphone...) và người dùng khỏi các mối đe dọa từ môi trường mạng như virus, phần mềm độc hại, tấn công lừa đảo và truy cập trái phép. Mục tiêu chính là ngăn chặn việc khai thác lỗ hổng từ phía người dùng – điểm yếu phổ biến nhất trong chuỗi an ninh mạng.

1.3 Các môi đe dọa phổ biến

- Phần mềm độc hại (Malware): bao gồm virus, worm, Trojan, ransomware...
- Phishing: kỹ thuật lừa đảo nhằm đánh cắp thông tin cá nhân qua email, website giả mạo.

- Tấn công mạng xã hội (Social Engineering): lợi dụng sự thiếu cảnh giác của người dùng để xâm nhập hệ thống.
- USB độc hại: thiết bị cắm ngoài chứa mã độc, tự động lây nhiễm khi kết nối.
- Truy cập trái phép: kẻ tấn công khai thác mật khẩu yếu hoặc lỗ hổng phần mềm để vào hệ thống.

1.4 Vai trò của bảo mật ở phía người dùng

- Bảo vệ dữ liệu cá nhân và tài khoản: ngăn kẻ xấu đánh cắp thông tin nhạy cảm.
- Ngăn chặn tấn công lan rộng trong mạng nội bộ: bảo vệ không chỉ bản thân mà còn toàn bộ hệ thống mạng.
- Tuân thủ chính sách an ninh doanh nghiệp: đảm bảo người dùng cuối không trở thành mắt xích yếu trong hệ thống.
- Tăng nhận thức an toàn thông tin: góp phần tạo thói quen sử dụng thiết bị an toàn và có ý thức.

1.5 Công nghệ hỗ trợ bảo mật người dùng cuối

- Xác thực hai yếu tố (2FA): Bổ sung lớp bảo mật bằng mã OTP gửi qua email hoặc điện thoại.
- Quản lý mật khẩu (Password Manager): Hỗ trợ lưu trữ mật khẩu an toàn và tạo mật khẩu mạnh.
- Giám sát hành vi người dùng (UEBA - User and Entity Behavior Analytics): Phân tích hành vi bất thường từ người dùng nhằm phát hiện truy cập trái phép.

1.5 Vai trò của người dùng cuối trong an ninh mạng

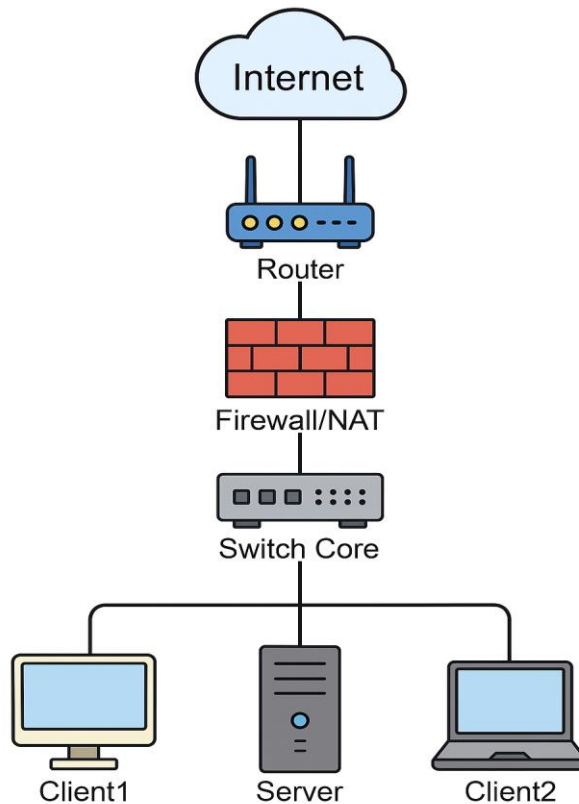
Người dùng cuối là điểm khởi đầu trong hầu hết các cuộc tấn công mạng, đặc biệt là tấn công phishing và social engineering. Do đó, việc đào tạo nhận thức bảo mật và xây dựng quy trình phản hồi sự cố là điều thiết yếu.

2. Kiến trúc mạng LAN cơ bản (Client – Server)

2.1 Các thành phần trong hệ thống

- Client (máy khách): là thiết bị đầu cuối (máy tính người dùng) yêu cầu dịch vụ từ server.

- Server (máy chủ): cung cấp các dịch vụ như DHCP, DNS, chia sẻ tệp, xác thực người dùng...
- Switch: thiết bị chuyển mạch, kết nối các máy tính trong mạng LAN.
- Router: định tuyến kết nối mạng LAN với các mạng khác (ví dụ: Internet).
- Firewall (tường lửa): kiểm soát lưu lượng truy cập vào/ra mạng, ngăn chặn truy cập trái phép.



Hình 1. Hệ thống mạng cơ bản

2.2 Các dịch vụ thường có

- DHCP (Dynamic Host Configuration Protocol): cấp phát địa chỉ IP tự động cho các thiết bị trong mạng.
- DNS (Domain Name System): phân giải tên miền thành địa chỉ IP.

- Domain Controller: quản lý người dùng, nhóm, và chính sách bảo mật trong hệ thống mạng sử dụng mô hình Windows Server.

2.3 Các giao thức mạng thường dùng

- HTTP/HTTPS: Truy cập website.
- FTP/SFTP: Truyền tệp.
- SMB/CIFS: Chia sẻ tệp trong mạng nội bộ.
- RDP, SSH: Điều khiển thiết bị từ xa.

3. Giới thiệu các giải pháp IDS/IPS

3.1 Khái niệm IDS và IPS

Để đảm bảo hệ thống có thể phát hiện và ngăn chặn các mối đe dọa từ bên ngoài, **IDS (Intrusion Detection System)** và **IPS (Intrusion Prevention System)** là hai giải pháp đóng vai trò quan trọng. IDS là hệ thống phát hiện xâm nhập, có khả năng theo dõi lưu lượng mạng và cảnh báo khi phát hiện các hành vi đáng ngờ. Trong khi đó, IPS là hệ thống ngăn chặn xâm nhập, hoạt động tương tự IDS nhưng có thêm khả năng chủ động ngăn chặn hành vi tấn công trước khi chúng gây hại.

3.2 Nguyên lý hoạt động

1. Thu thập dữ liệu mạng: từ thiết bị mạng như switch, router hoặc tường lửa.
2. Phân tích gói tin: sử dụng tập hợp quy tắc (rule set) để so sánh với các mẫu tấn công đã biết.
3. Phát hiện và cảnh báo (IDS) hoặc ngăn chặn (IPS) hành vi đáng ngờ như quét cổng, brute force, mã độc...
4. Ghi nhật ký (log) và gửi thông báo đến quản trị viên.

3.3 Ví dụ các công cụ IDS/IPS phổ biến

- Snort: một trong những công cụ IDS/IPS nổi tiếng, cho phép người dùng viết các rule tùy chỉnh để phát hiện hành vi cụ thể.
- Suricata: công cụ hiện đại hơn với khả năng đa luồng, hỗ trợ IDS, IPS và cả Network Security Monitoring (NSM).
- OSSEC: hệ thống phát hiện xâm nhập dựa trên máy chủ (host-based).
- Wazuh : là công cụ bảo mật cài trên máy chủ/máy trạm để phát hiện và cảnh báo hành vi đáng ngờ trong hệ thống.

3.4 Phân loại IDS/IPS

1. Network-based IDS/IPS (NIDS/NIPS)

Network-based IDS (NIDS) và Network-based IPS (NIPS) là những hệ thống được đặt tại các vị trí chiến lược trong mạng, chẳng hạn như ngay sau router hoặc tại điểm ra/vào mạng, nơi có thể theo dõi toàn bộ lưu lượng đi qua.

Chức năng:

- NIDS giám sát tất cả lưu lượng mạng, phân tích các gói dữ liệu để phát hiện những dấu hiệu tấn công hoặc hành vi bất thường như quét cổng (port scanning), brute force, tấn công DDoS...
- NIPS không chỉ phát hiện như NIDS mà còn có khả năng ngăn chặn, ví dụ như tự động block IP, reset kết nối hoặc cảnh báo admin ngay khi phát hiện mối nguy.

Ưu điểm:

- Quan sát được toàn bộ lưu lượng qua mạng → phát hiện các mối đe dọa lan rộng.
- Không cần cài đặt lên từng thiết bị → dễ quản lý.

Hạn chế:

- Không thể phát hiện những tấn công đã vượt qua lớp mạng và hoạt động bên trong máy (ví dụ: malware ẩn trong thiết bị người dùng).
- Dễ bị quá tải nếu mạng lớn và lưu lượng cao.

2. Host-based IDS/IPS (HIDS/HIPS)

Ngược lại với NIDS/NIPS, Host-based IDS (HIDS) và Host-based IPS (HIPS) là các giải pháp được cài đặt trực tiếp trên từng thiết bị đầu cuối (endpoint), như máy tính cá nhân, máy chủ hoặc laptop.

Chức năng:

- HIDS giám sát các tệp tin hệ thống, tiến trình đang chạy, log hệ điều hành, registry (trên Windows)... để phát hiện các hành vi đáng ngờ từ bên trong thiết bị.
- HIPS có thể chủ động ngăn chặn hoặc can thiệp khi phát hiện phần mềm độc hại hoặc các hành vi tấn công cục bộ (ví dụ như keylogger, truy cập trái phép tới file hệ thống).

Ưu điểm:

- Phát hiện được các mối nguy mà NIDS/NIPS không thấy như: malware chạy ngầm, thay đổi trái phép trong file hệ thống.
- Có thể kiểm soát kỹ hành vi nội bộ của người dùng hoặc phần mềm trên máy.

Hạn chế:

- Cần cài đặt và cấu hình riêng trên từng máy → khó quản lý khi số lượng thiết bị lớn.
- Có thể bị tin tặc vô hiệu hóa nếu hệ thống đã bị xâm nhập.

Tóm lại:

Nếu ví hệ thống bảo mật là một ngôi nhà, thì NIDS/NIPS giống như camera và cửa an ninh ở cổng, còn HIDS/HIPS giống như khóa và chuông báo động trong từng phòng. Để đảm bảo an toàn toàn diện, cần kết hợp cả hai loại công nghệ này nhằm bảo vệ cả bên ngoài lẫn bên trong hệ thống mạng.

3.5 Bản so sánh

Tiêu chí	IDS (Hệ thống phát hiện xâm nhập)	IPS (Hệ thống ngăn chặn xâm nhập)
Chức năng chính	Phát hiện và cảnh báo các hành vi xâm nhập	Phát hiện và chặn các hành vi xâm nhập
Vị trí triển khai	Sau firewall, thường ở chế độ giám sát mạng	Trực tiếp trong luồng mạng, chặn lưu lượng độc hại
Khả năng can thiệp	Không can thiệp vào lưu lượng, chỉ ghi log và cảnh báo	Có thể can thiệp, chặn hoặc ngắt kết nối
Rủi ro khi vận hành	Ít rủi ro, không ảnh hưởng đến hệ thống	Có thể gây gián đoạn dịch vụ nếu cấu hình sai
Hiệu năng mạng	Không ảnh hưởng đến hiệu năng	Có thể ảnh hưởng nếu hệ thống không đủ mạnh
Khó khăn khi triển khai	Dễ triển khai, cấu hình đơn giản	Cần cấu hình cẩn thận để tránh false positive
Ứng dụng phù hợp	Hệ thống cần giám sát và ghi nhận sự kiện	Môi trường yêu cầu ngăn chặn chủ động các mối đe dọa
Ví dụ công cụ phổ biến	Snort (chế độ IDS), OSSEC	Suricata, Snort (chế độ IPS), pfSense + Snort

Bảng 1. Bảng so sánh IDS và IPS

Tóm lại:

- IDS thích hợp cho mục tiêu giám sát, phân tích nhật ký, không gây ảnh hưởng đến hoạt động mạng.
- IPS phù hợp khi hệ thống yêu cầu phản ứng ngay lập tức, tự động ngăn chặn tấn công, nhưng phải được cấu hình và giám sát kỹ để tránh chặn nhầm.

3.6 Các phương pháp phát hiện

- Phát hiện theo mẫu (Signature-based): So sánh với mẫu tấn công đã biết.
- Phát hiện bất thường (Anomaly-based): Phát hiện hành vi khác thường so với chuẩn.
- Hybrid (Kết hợp): Sử dụng cả hai phương pháp để nâng cao hiệu quả phát hiện.

4. Giới thiệu các giải pháp System Endpoint

4.1 Khái niệm Endpoint Protection

Endpoint Protection là các biện pháp và phần mềm bảo mật được triển khai trên thiết bị đầu cuối (endpoint) như máy tính, laptop, điện thoại để bảo vệ khỏi tấn công mạng và phần mềm độc hại. Endpoint được xem là "cửa ngõ" quan trọng cần được bảo vệ kỹ lưỡng trong hệ thống.

- **Endpoint Protection Platform (EPP):** Đây là các giải pháp phòng ngừa chủ động, thường bao gồm tường lửa cá nhân, chống virus, kiểm soát thiết bị ngoại vi, và lọc web. Mục tiêu của EPP là ngăn chặn các mối đe dọa trước khi chúng kịp thực thi trên thiết bị.
- **Endpoint Detection and Response (EDR):** Khác với EPP, EDR tập trung vào việc phát hiện và phản ứng với các hành vi đáng ngờ sau khi mối đe dọa đã xâm nhập. EDR có khả năng thu thập dữ liệu, phân tích hành vi người dùng và phần mềm, từ đó phát hiện ra các cuộc tấn công tinh vi, khó nhận biết như APT (Advanced Persistent Threat).

4.2 Vai trò và tính năng

- Phát hiện và ngăn chặn phần mềm độc hại (Antivirus/Antimalware).
- Tường lửa cá nhân: kiểm soát kết nối mạng tại thiết bị.
- Chống khai thác lỗ hổng (Exploit Protection): ngăn mã độc khai thác phần mềm lỗi thời.
- Quản lý thiết bị từ xa: hỗ trợ IT theo dõi và triển khai bản vá, cập nhật phần mềm bảo mật.
- Mã hóa dữ liệu (Data Encryption): bảo vệ dữ liệu trong trường hợp thiết bị bị đánh cắp.

4.3 Các phần mềm phổ biến

- Windows Defender Endpoint Protection: tích hợp sẵn trong Windows 10/11.
- Kaspersky Endpoint Security
- Bitdefender GravityZone
- Symantec Endpoint Protection
- ESET Endpoint Security
- Sophos Intercept X

4.4 Các loại endpoint cần bảo vệ

- Máy tính cá nhân (PC, laptop)
- Thiết bị di động (Smartphone, tablet)
- Máy in, thiết bị IoT trong mạng nội bộ

4.5 Các mối đe dọa cụ thể với endpoint

- Ransomware: Mã hóa toàn bộ dữ liệu trên thiết bị và đòi tiền chuộc.
- Keylogger: Ghi lại mọi thao tác bàn phím, đánh cắp thông tin đăng nhập.
- Zero-day: Tấn công vào lỗ hổng chưa được phát hiện và vá lỗi.

5. Tổng kết chương

Chương này đã trình bày tổng quan các kiến thức lý thuyết nền tảng liên quan đến bảo mật người dùng cuối, kiến trúc mạng LAN dạng client-server, hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS), cùng với các biện pháp bảo vệ endpoint – một trong những tuyến phòng thủ đầu tiên trong hệ thống mạng. Những kiến thức này đóng vai trò quan trọng làm nền tảng cho việc triển khai, đánh giá và cải tiến hệ thống bảo mật mạng trong các chương sau của đề án.

CHƯƠNG II LÊN KẾ HOẠCH TRIỂN KHAI

1. Mục tiêu

- Đảm bảo hạ tầng mạng an toàn, ổn định và dễ quản lý.
- Phân tách lưu lượng giữa LAN nội bộ, DMZ và Internet để hạn chế rủi ro.
- Thiết lập chính sách truy cập phù hợp cho từng nhóm người dùng (VLAN).
- Tích hợp hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS) với Snort trên pfSense.

2. Phạm vi

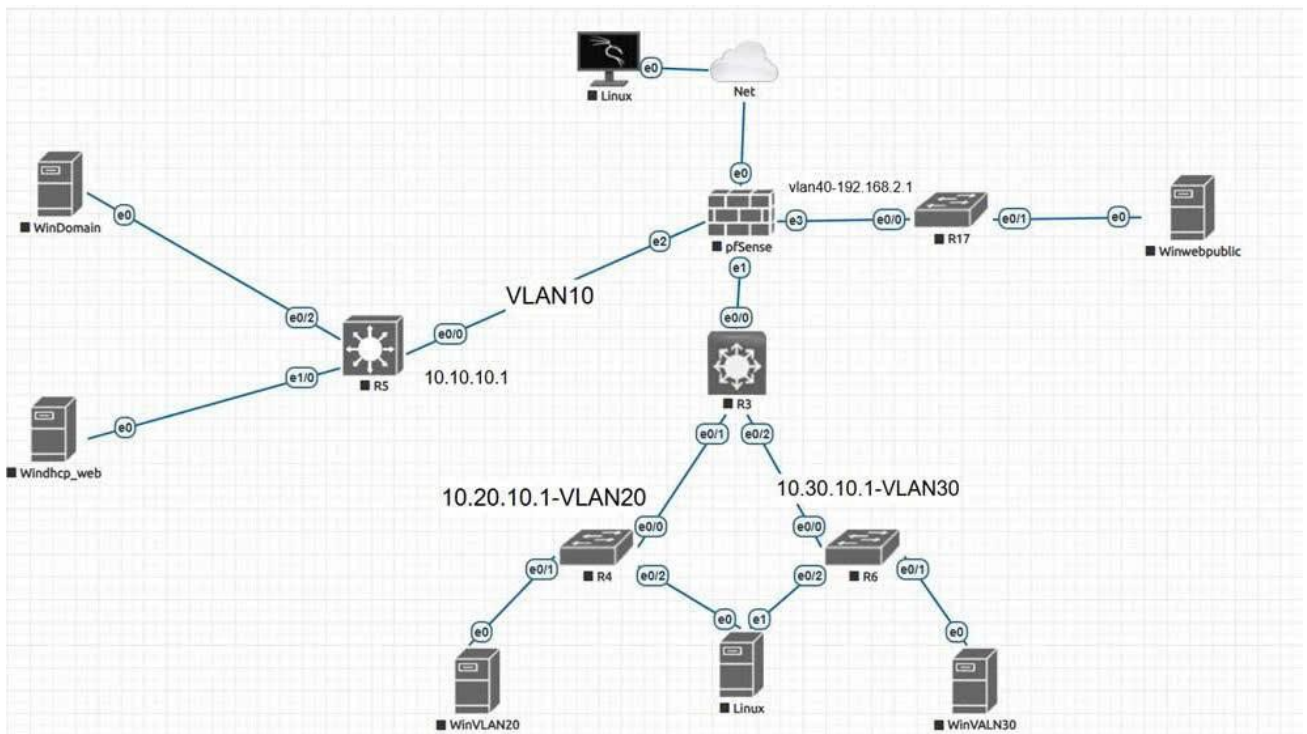
Thành phần	Số lượng	Vai trò
Firewall pfSense	1	Định tuyến, phân vùng mạng, IPS/IDS
Windows Server	1 Domain	Domain Controller, DNS, DHCP
Windows Server	1 Nội bộ	Web server nội bộ
Windows Server	1 Public	Web server công khai
Máy Client	3	Truy cập dịch vụ nội bộ và Internet

3. Tài nguyên và nhân sự

- **Phần cứng:**
 - 1 máy chủ cấu hình CPU ≥ 4 cores, RAM ≥ 8 GB, 4 NIC.
 - 3 máy ảo Windows Server (vCPU 2, RAM 4 GB).
 - 4 máy ảo Windows 10/11 (vCPU 1, RAM 2 GB).
- **Phần mềm:**
 - pfSense 2.x
 - Snort++ 3.x
 - Windows Server 2019/2022
 - Công cụ kiểm thử (Metasploit, nmap, Wireshark)
- **Nhân sự:**
 - 1 Quản trị mạng (cài đặt, cấu hình pfSense & server).
 - 1 Chuyên gia bảo mật (viết rule Snort, đánh giá IPS/IDS).
 - 1 Kỹ sư kiểm thử nội bộ (kiểm thử xâm nhập).

4. Thiết kế kiến trúc mạng

- **VLAN & phân vùng:**
 - VLAN10 (LAN nội bộ – Users): truy cập Internet không giới hạn.
 - VLAN20 (LAN nội bộ – Nhân viên): truy cập bị giới hạn.
 - VLAN30 (Phòng ban quản lý): truy cập nội bộ & web giải trí có kiểm soát.
 - VLAN40 (Thiết bị bảo mật/IoT): không truy cập Internet.
- **Sơ đồ logic:**
 - e0 → WAN (Internet)
 - e1 → VLAN10, VLAN20, VLAN30 (trên cùng switch vật lý, trunk)
 - e2 → DMZ (Domain Controller)
 - e3 → DMZ (Web public)
 - e4 → (dự phòng/NAT nội bộ)



Hình 2. Sơ đồ mạng

5. Chiến lược cấu hình

1. Cấu hình cơ bản pfSense

- Gán IP cho mỗi interface, bật NAT trên WAN.
- Thiết lập DHCP cho VLAN10/20/30.

2. Thiết lập VLAN trên switch

- Cấu hình trunk giữa pfSense e1 và switch core.
- Đánh dấu VLAN tương ứng trên các port access.

3. Định nghĩa Aliases & Rules cơ bản

- Alias “Internal_Networks” (LAN10,20,30).
- Alias “Restricted_Sites” (danh sách web cần chặn cho VLAN20/30).

4. Chính sách firewall

- VLAN10: allow any → any (outbound).
- VLAN20/30: allow LAN → LAN; allow LAN → WAN port 80/443 nhưng block “Restricted_Sites”.
- VLAN40: block any → WAN.

5. Tích hợp Snort/Suricata

- Cài Snort package trên pfSense.
- Import rule từ “Snort Community Rules”.
- Master mode trên WAN cho IPS, inline mode cho LAN.
- Test rule mẫu (e.g., phát hiện port scan, HTTP exploit).

6. Nguyên lý hoạt động

Cấu Trúc Hệ Thống:

Kernel của FreeBSD: pfSense được xây dựng trên nền tảng hệ điều hành FreeBSD, cung cấp một nền tảng ổn định và bảo mật.

Packet Filter (pf): Đây là trái tim của pfSense, chịu trách nhiệm chính trong việc lọc các gói tin (packets). pf là một firewall stateful, nghĩa là nó theo dõi trạng thái của các kết nối mạng đi qua nó.

Tường Lửa (Firewall): pfSense sử dụng pf để lọc và kiểm soát lưu lượng mạng dựa trên các quy tắc (rules) được thiết lập.

Các quy tắc này có thể dựa trên các tiêu chí như địa chỉ IP, cổng, giao thức, và nhiều yếu tố khác.

Router: pfSense có thể hoạt động như một router, chuyển tiếp các gói tin giữa các mạng khác nhau. Nó hỗ trợ nhiều giao thức định tuyến như OSPF, BGP và RIP.

NAT (Network Address Translation): pfSense hỗ trợ NAT để dịch các địa chỉ IP nội bộ sang địa chỉ IP công cộng và ngược lại, giúp che giấu cấu trúc mạng nội bộ và cải thiện bảo mật.

VPN (Virtual Private Network): pfSense hỗ trợ nhiều loại VPN như IPsec, OpenVPN, và PPTP, cho phép tạo các kết nối mạng an toàn qua Internet.

DHCP Server: pfSense có thể cung cấp dịch vụ DHCP, tự động gán địa chỉ IP cho các thiết bị trong mạng nội bộ.

DNS: pfSense có thể hoạt động như một DNS forwarder hoặc DNS resolver, cung cấp dịch vụ DNS cho mạng nội bộ.

Quản Lý và Giám Sát:

Giao Diện Web: pfSense cung cấp một giao diện web thân thiện cho việc quản lý và cấu hình. Người quản trị có thể thiết lập các quy tắc firewall, cấu hình VPN, theo dõi lưu lượng mạng và nhiều chức năng khác qua giao diện này.

Giám Sát (Monitoring): pfSense tích hợp nhiều công cụ giám sát như RRD graphs, hệ thống logging chi tiết, và các công cụ phân tích lưu lượng mạng.

Tính Năng Bảo Mật:

- **Intrusion Detection and Prevention System (IDS/IPS):** pfSense hỗ trợ tích hợp các công cụ IDS/IPS như Snort và Suricata, giúp phát hiện và ngăn chặn các mối đe dọa mạng.
- **Cập Nhật Bảo Mật:** pfSense thường xuyên cập nhật các bản vá bảo mật và nâng cấp hệ thống để bảo vệ chống lại các lỗ hổng mới phát hiện.

Ứng dụng triển khai

pfSense có thể được triển khai trong nhiều môi trường khác nhau, từ các doanh nghiệp nhỏ đến các tổ chức lớn, bao gồm:

Báo Cáo Học Tập

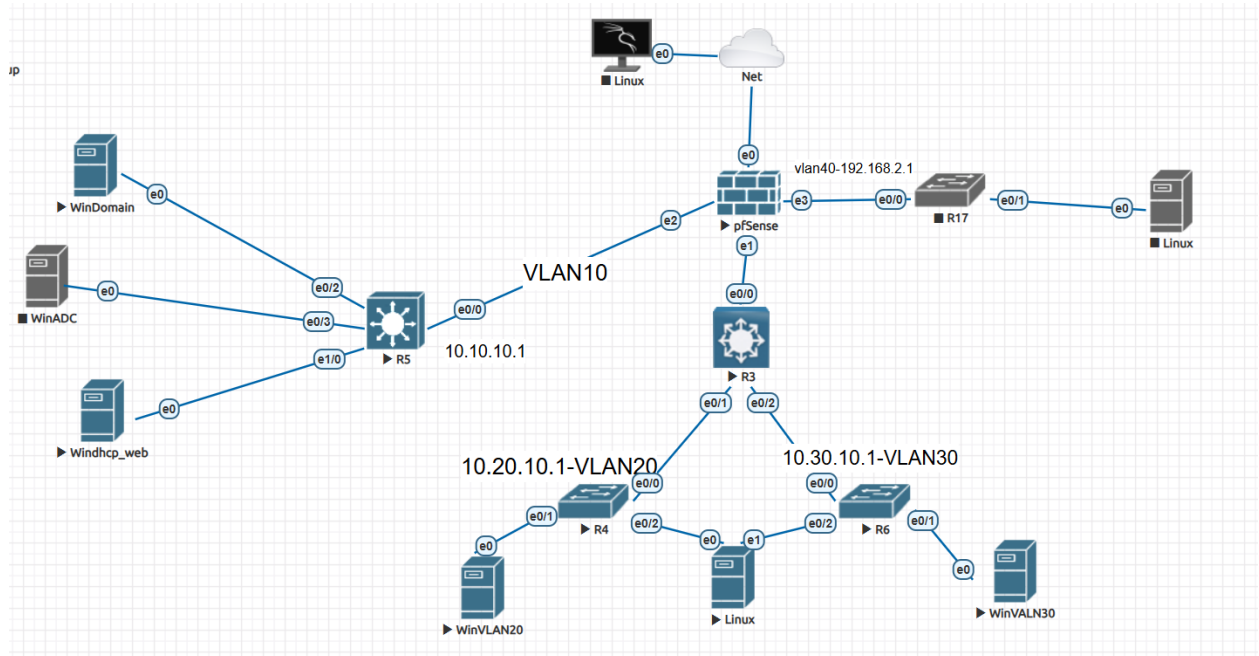
Mạng doanh nghiệp: Cung cấp tường lửa và router cho mạng nội bộ của doanh nghiệp.

Nhà cung cấp dịch vụ (ISP): Sử dụng pfSense để quản lý và bảo vệ mạng của các khách hàng.

Mạng gia đình: pfSense có thể được sử dụng để bảo vệ mạng gia đình và quản lý các thiết bị kết nối Internet.

CHƯƠNG III TRIỂN KHAI

1. Sơ đồ triển khai



Hình 3. Sơ đồ triển khai

Tổng quan thiết bị:

- 1 Firewall Pfsense
- 4 máy server(1 domain, 1 web nội bộ, 1 web public, 1 máy OSSEC)
- 4 máy PC(3 máy Client và một máy attacker)

Tổ chức thiết kế:

Pfsense có 4 card mạng là e0→e4

E0 sẽ kết nối đến Internet

E1 sẽ kết nối cho mạng LAN(Mạng nội bộ)

E2 sẽ kết nối cho môi trường DMZ(Win Server)

E3 sẽ kết nối với web server publicip

2. Cấu hình cơ bản cho pfsense

The screenshot shows the pfSense web interface in a Google Chrome browser. The address bar displays "https://10.10.10.1:444/system.php" with a "Not secure" warning. The browser's default browser notification bar is visible. The pfSense interface has a dark header with the logo and navigation menu items: System, Interfaces, Firewall, Services, VPN, Status, Diagnostics, and Help. The main content area is titled "System / General Setup".

System

Hostname
Name of the firewall host, without domain part.

Domain
Domain name for the firewall.

Do not end the domain name with '.local' as the final part (Top Level Domain, TLD). The 'local' TLD is widely used by mDNS (e.g. Avahi, Bonjour, Rendezvous, Airprint, Airplay) and some Windows systems and networked devices. These will not network correctly if the router uses 'local' as its TLD. Alternatives such as 'home.arpa', 'local.lan', or 'mylocal' are safe.

DNS Server Settings

DNS Servers	DNS Hostname	
8.8.8.8		<button>Delete</button>
8.8.4.4		<button>Delete</button>

Address
Enter IP addresses to be used by the system for DNS resolution. These are also used for the DHCP service, DNS Forwarder and DNS

Hostname
Enter the DNS Server Hostname for TLS Verification in the DNS Resolver (optional).

Hình 4. Cấu hình ban đầu cho Pfsense



The image shows a terminal window titled "pfSense" with standard window controls. The terminal output displays the Netgate Device ID, a welcome message for pfSense 2.7.0-RELEASE (amd64), and a list of network interfaces with their assigned IP addresses. Below this is a menu of 16 options for system management.

```

QEMU Guest - Netgate Device ID: f6ff800ec7292e020d4a

*** Welcome to pfSense 2.7.0-RELEASE (amd64) on pfSense ***

WAN (wan)      -> vtnet0      -> v4/DHCP4: 192.168.32.140/24
LAN (lan)      -> vtnet2.10  -> v4: 10.10.10.1/24
OPT1 (opt1)    -> vtnet1.20  -> v4: 10.20.10.1/24
OPT2 (opt2)    -> vtnet1.30  -> v4: 10.30.10.1/24
OPT3 (opt3)    -> vtnet3.40  -> v4: 192.168.2.1/24
OPT4 (opt4)    -> vtnet4      -> v4: 192.168.10.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell
  
```

Hình 5. Giao diện cấu hình và quản lý bằng dòng lệnh đã được setup IP và ping ra ngoài Internet

The screenshot shows the pfSense web interface accessed via a browser at the URL `https://10.10.10.1:444`. The interface is divided into two main sections: System Status on the left and Network Interfaces on the right.

System Status:

- CPU Type:** QEMU Virtual CPU version 2.5+
2 CPUs: 2 package(s) x 1 core(s)
AES-NI CPU Crypto: No
QAT Crypto: No
- Hardware crypto:** Inactive
- Kernel PTI:** Enabled
- MDS Mitigation:** Inactive
- Uptime:** 00 Hour 09 Minutes 51 Seconds
- Current date/time:** Thu Jul 10 20:49:58 +07 2025
- DNS server(s):**
 - 127.0.0.1
 - 192.168.32.2
 - 8.8.8.8
 - 8.8.4.4
- Last config change:** Tue May 13 19:39:34 +07 2025
- State table size:** 0% (122/199000) [Show states](#)
- MBUF Usage:** 1% (762/124042)
- Load average:** 0.44, 0.50, 0.30

Network Interfaces:

Interface	Speed	Duplex	IP Address
WAN	10Gbase-T	<full-duplex>	192.168.32.140
LAN	10Gbase-T	<full-duplex>	10.10.10.1
OPT1	10Gbase-T	<full-duplex>	10.20.10.1
OPT2	10Gbase-T	<full-duplex>	10.30.10.1
OPT3	10Gbase-T	<full-duplex>	192.168.2.1

Support Information:

worldwide support at a price point that is more than competitive when compared to others in our space.

- Upgrade Your Support**
- Community Support Resources**
- Netgate Global Support FAQ**
- Official pfSense Training by Netgate**
- Netgate Professional Services**
- Visit Netgate.com**

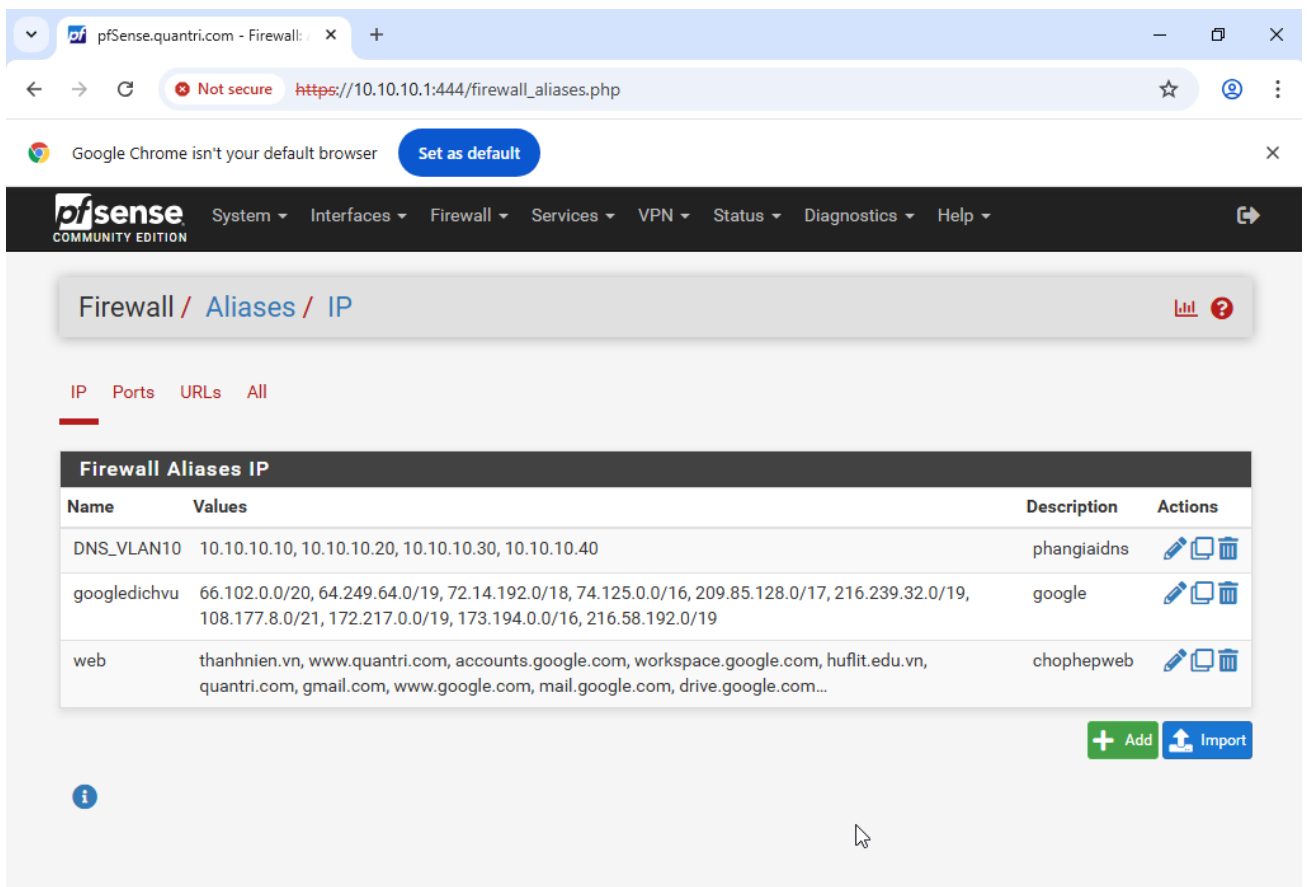
If you decide to purchase a Netgate Global TAC Support subscription, you **MUST** have your **Netgate Device ID (NDI)** from your firewall in order to validate support for this unit. Write down your NDI and store it in a safe place. You can purchase TAC supports [here](#).

Hình 6. Giao diện cấu hình và quản lý bằng GUI thông qua địa chỉ IP default gateway và port

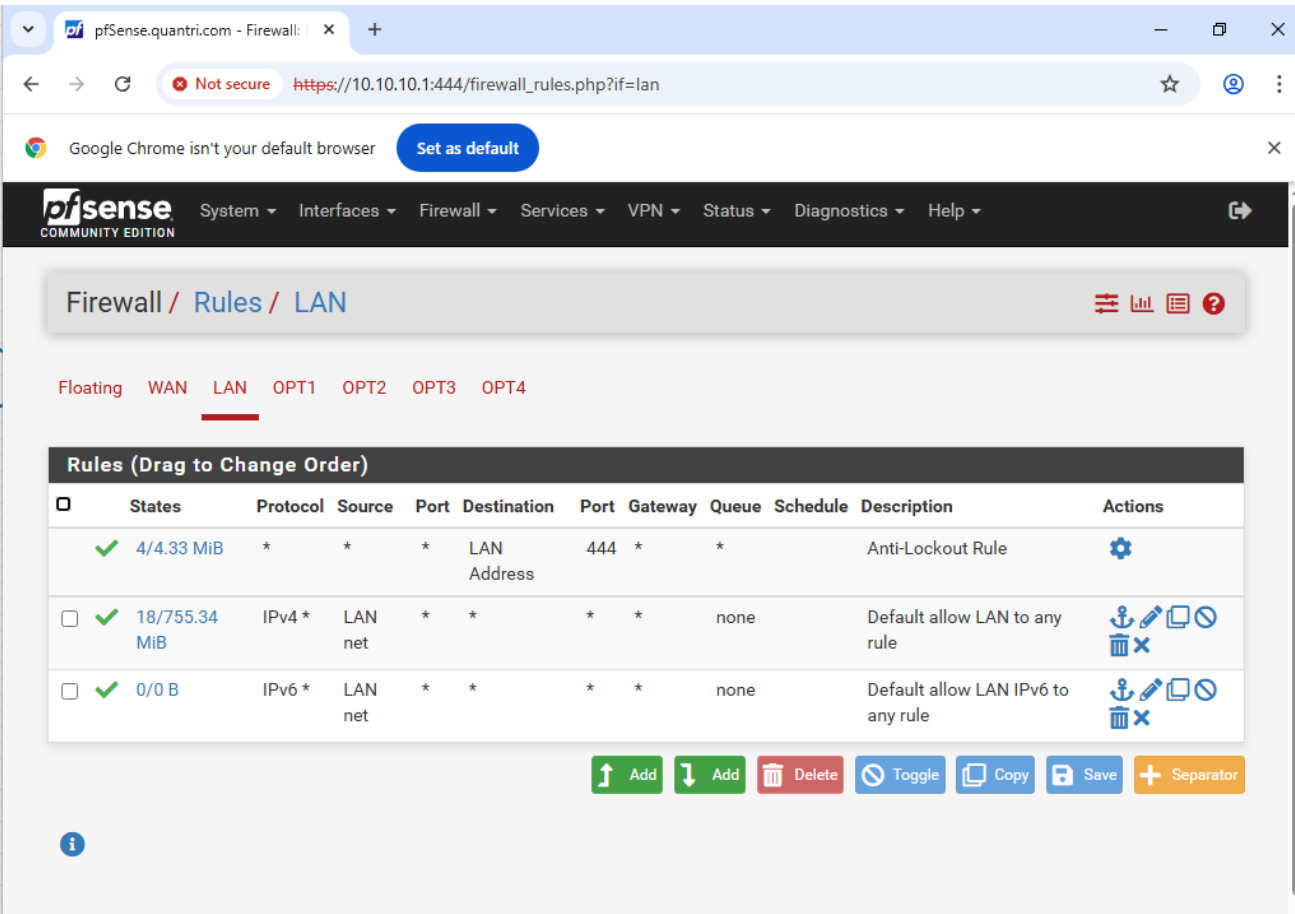
3. Quản lí người dùng cuối

Chính sách quản lí người dùng theo từng vlan

Vlan10	Internet không giới hạn, không bị quản lý	Cho phép truy cập mọi trang web không giới hạn
Vlan20 Vlan30	Internet giới hạn nhẹ, bị quản lý	Chỉ được truy cập các web nội bộ hoặc các web giải trí khác nhưng bị giới hạn các web cụ thể
Vlan40	Không có internet	Ngắt hoàn toàn internet



Hình 7. Định nghĩa các aliases để phù hợp với các phân cấp vlan



Hình 8. Tạo các rules cho Vlan10, không bị giới hạn

Báo Cáo Học Tập

pfSense.quantri.com - Firewall: × +

← → ↻ Not secure https://10.10.10.1:444/firewall_rules.php?if=opt1 ☆ ⓘ ⋮

Google Chrome isn't your default browser [Set as default](#) ×

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B IPv4 *	OPT1 net	*	googledichvu	*	*	none			
☐	✓	0/0 B IPv4 *	OPT1 net	*	web	*	*	none		không cho phép truy cập facebook	
☐	✗	0/0 B IPv4 *	OPT1 net	*	WAN net	*	*	none			
☐	✗	0/0 B IPv4 *	OPT1 net	*	OPT2 net	*	*	none			
☐	✗	0/0 B IPv4 *	OPT1 net	*	OPT3 net	*	*	none			
☐	✓	0/0 B IPv4 TCP/UDP	OPT1 net	*	DNS_VLAN10	53 (DNS)	*	none		chophepdns	
☐	✗	0/0 B IPv4 ICMP any	OPT1 net	*	DNS_VLAN10	*	*	none		chanpingvlan10	
☐	✗	0/0 B IPv4 *	OPT1 net	*	This Firewall	*	*	none			
☐	✓	0/0 B IPv4 *	OPT1 net	*	LAN net	*	*	none			

Thursday, July 10, 2025

Hình 9. Tạo các rules cho Vlan20, không bị giới hạn

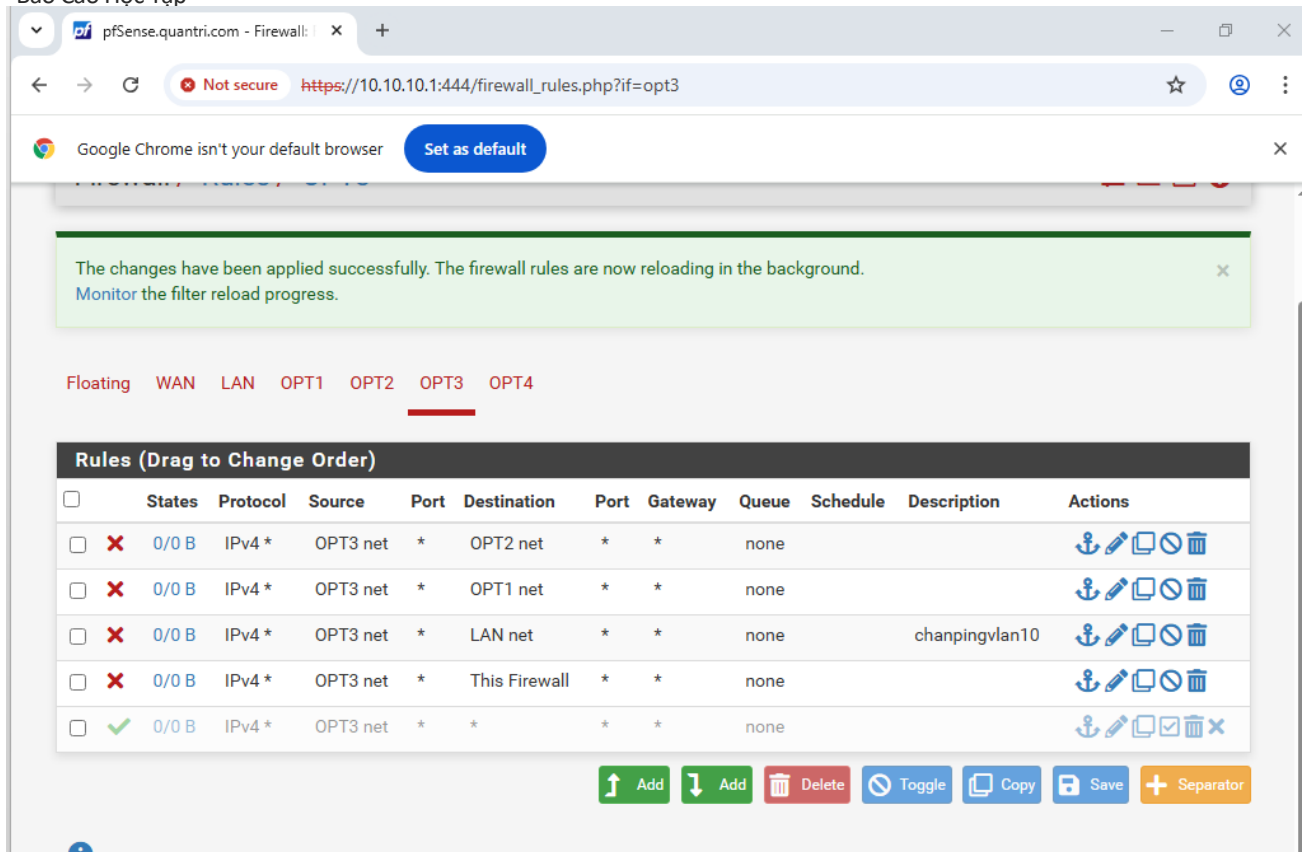
pfSense.quantri.com - Firewall: | X +

Not secure https://10.10.10.1:444/firewall_rules.php?if=opt2

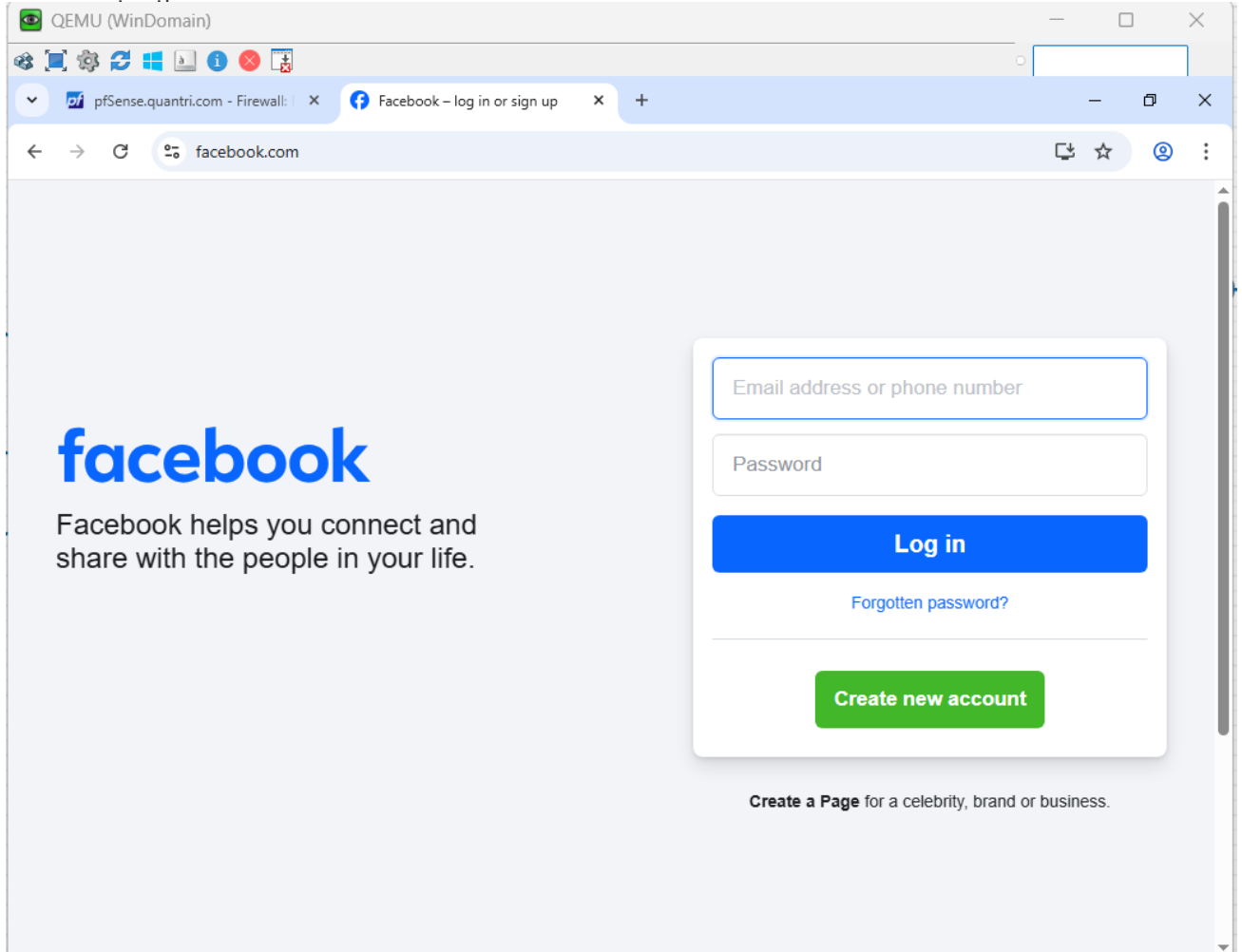
Google Chrome isn't your default browser Set as default

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0/0 B	IPv4 *	OPT2 net	*	googledichvu	*	*	none			
☐	✓ 0/0 B	IPv4 *	OPT2 net	*	web	*	*	none		không cho phép truy cập facebook	
☐	✗ 0/0 B	IPv4 *	OPT2 net	*	WAN net	*	*	none			
☐	✗ 0/0 B	IPv4 *	OPT2 net	*	OPT1 net	*	*	none			
☐	✗ 0/0 B	IPv4 *	OPT2 net	*	OPT3 net	*	*	none			
☐	✓ 0/0 B	IPv4 TCP/UDP	OPT2 net	*	DNS_VLAN10	53 (DNS)	*	none		chophepdns	
☐	✗ 0/0 B	IPv4 ICMP any	OPT2 net	*	DNS_VLAN10	*	*	none		chanpingvlan10	
☐	✗ 0/0 B	IPv4 *	OPT2 net	*	This Firewall	*	*	none			
☐	✓ 0/0 B	IPv4 *	OPT2 net	*	LAN net	*	*	none			
☐	✓ 0/0 B	IPv4 *	OPT2 net	*	*	*	*	none			

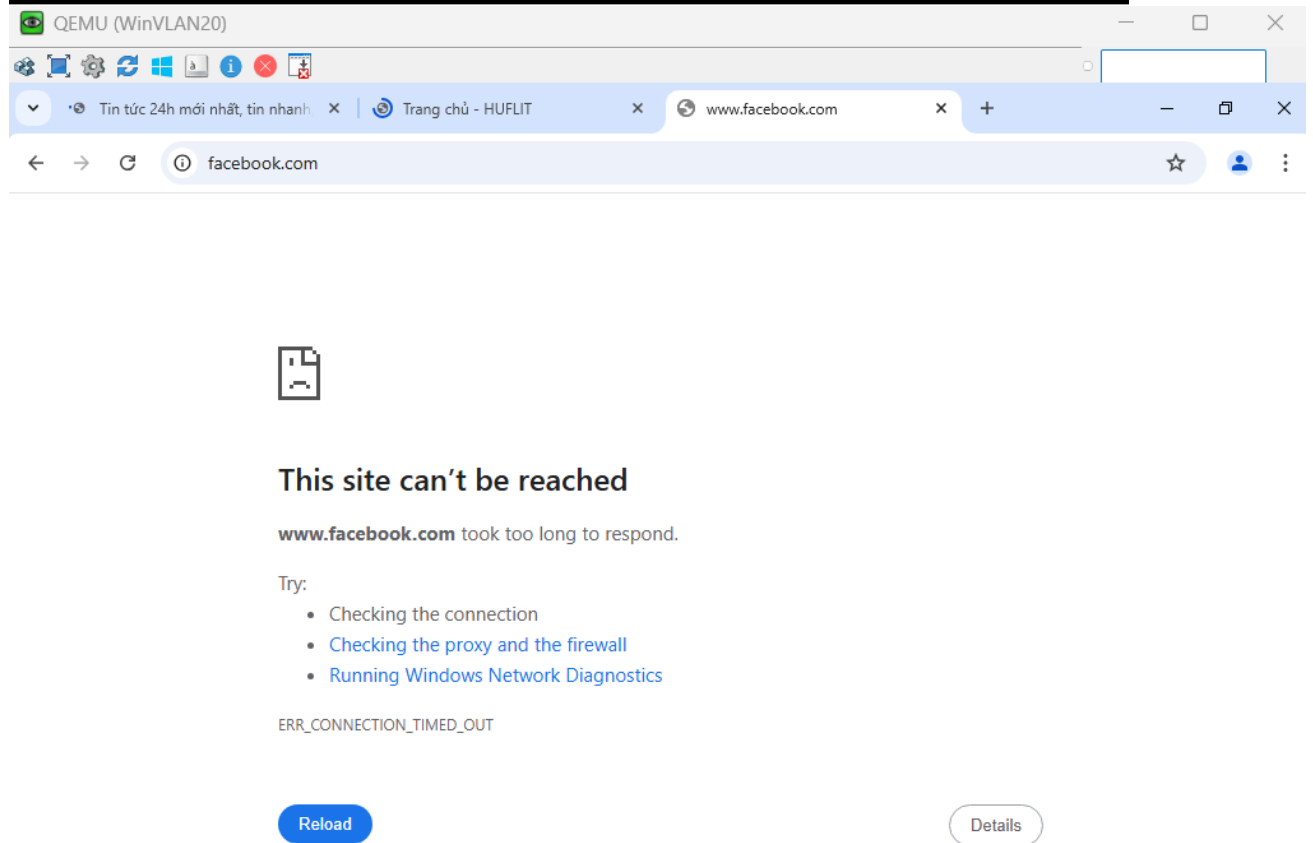
Hình 10. Tạo các rules cho Vlan30, không bị giới hạn



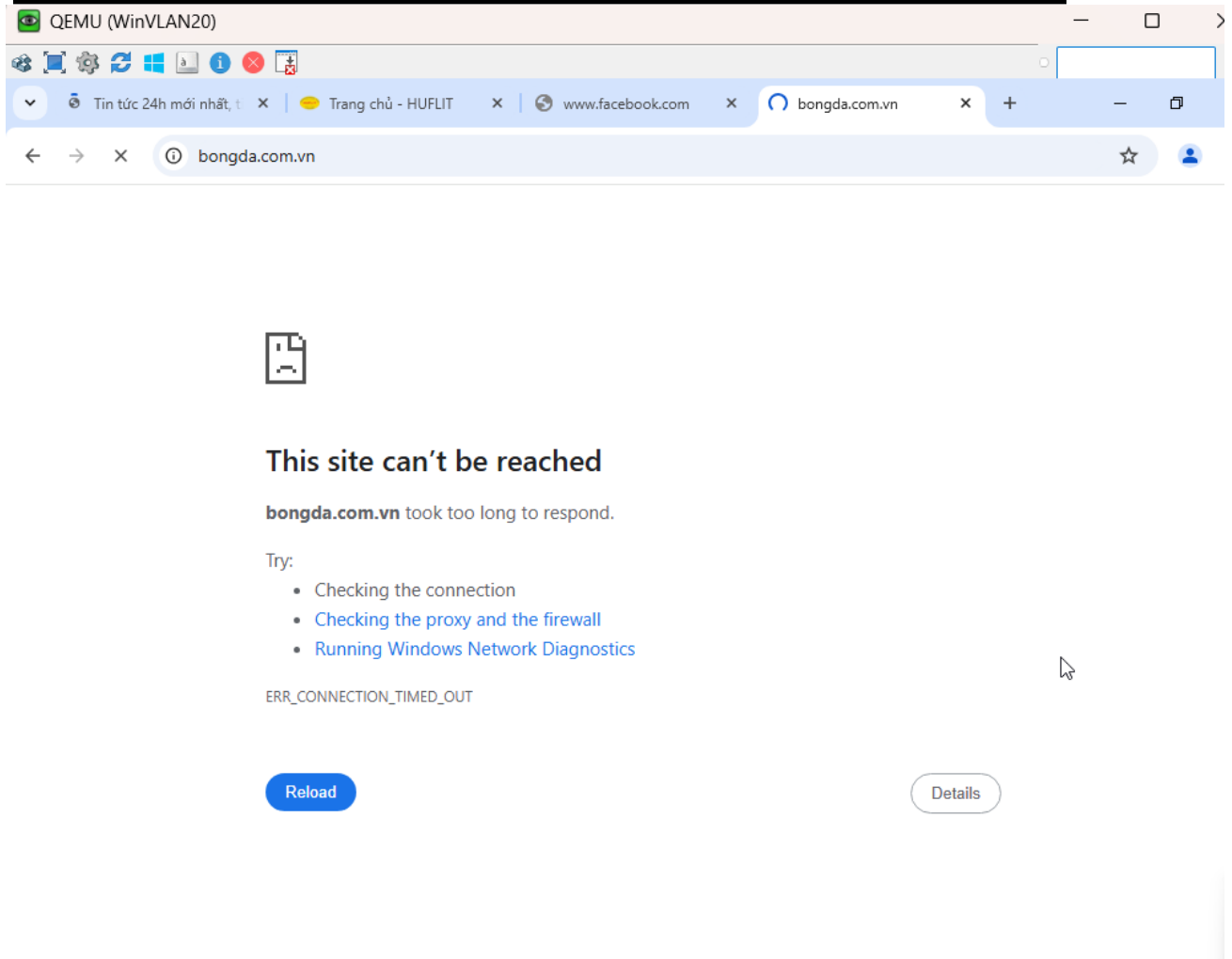
Hình 11. Tạo các rule cho vlan 40 không cho ra internet



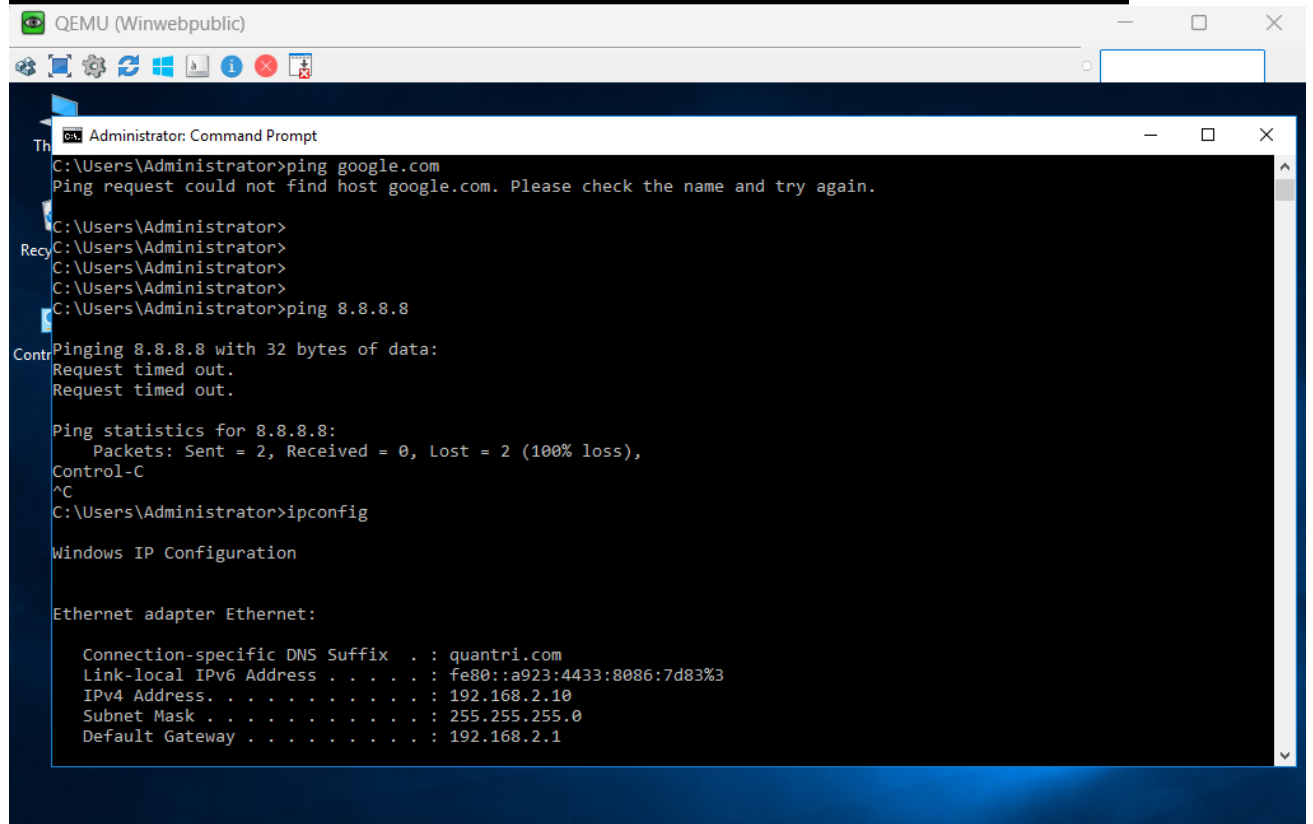
Hình 12. Người dùng vlan10 truy cập không giới hạn thành công



Hình 13. Người dùng vlan20,30 truy cập trang facebook không thành công

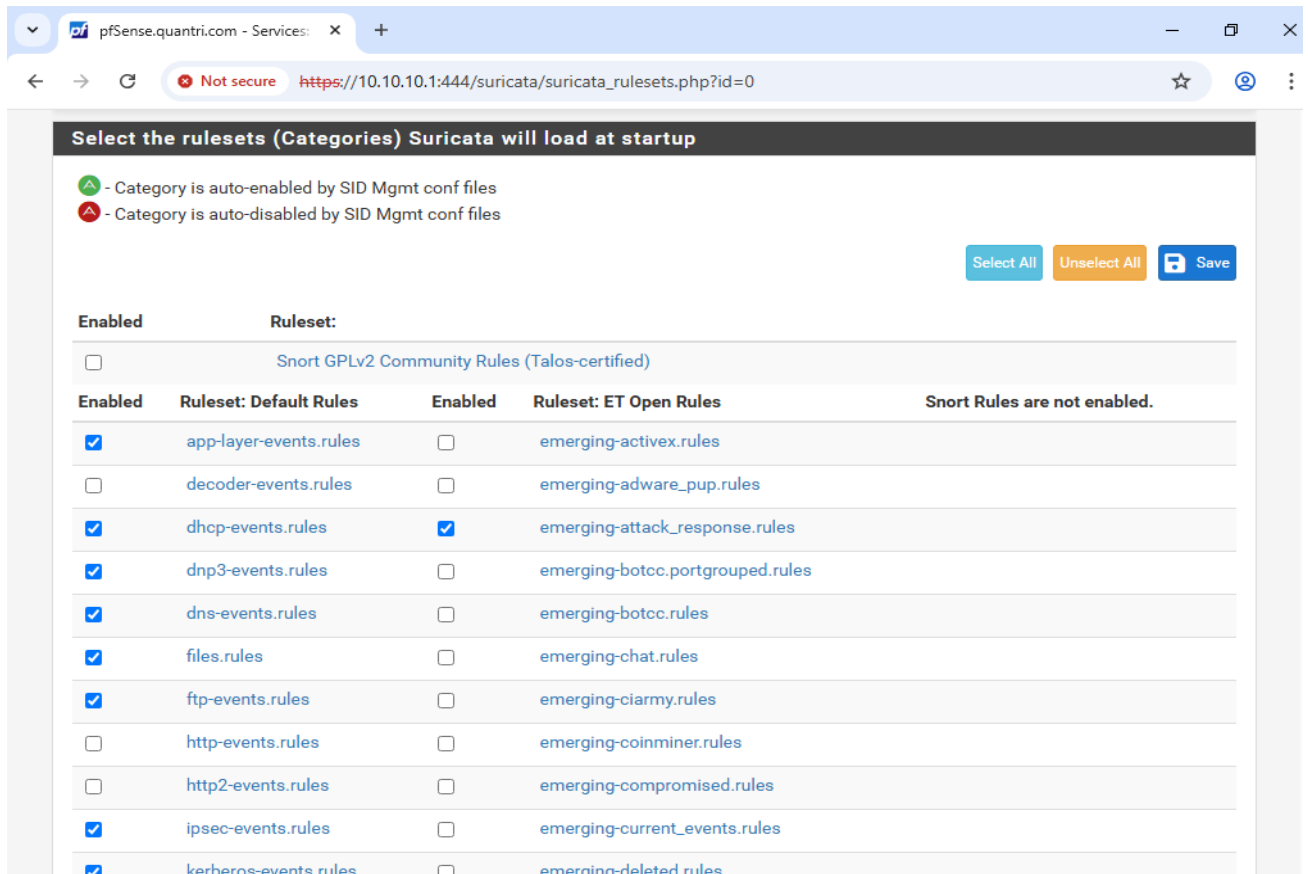


Hình 14. Người dùng vlan20,30 truy cập trang bongda.com.vn không thành công



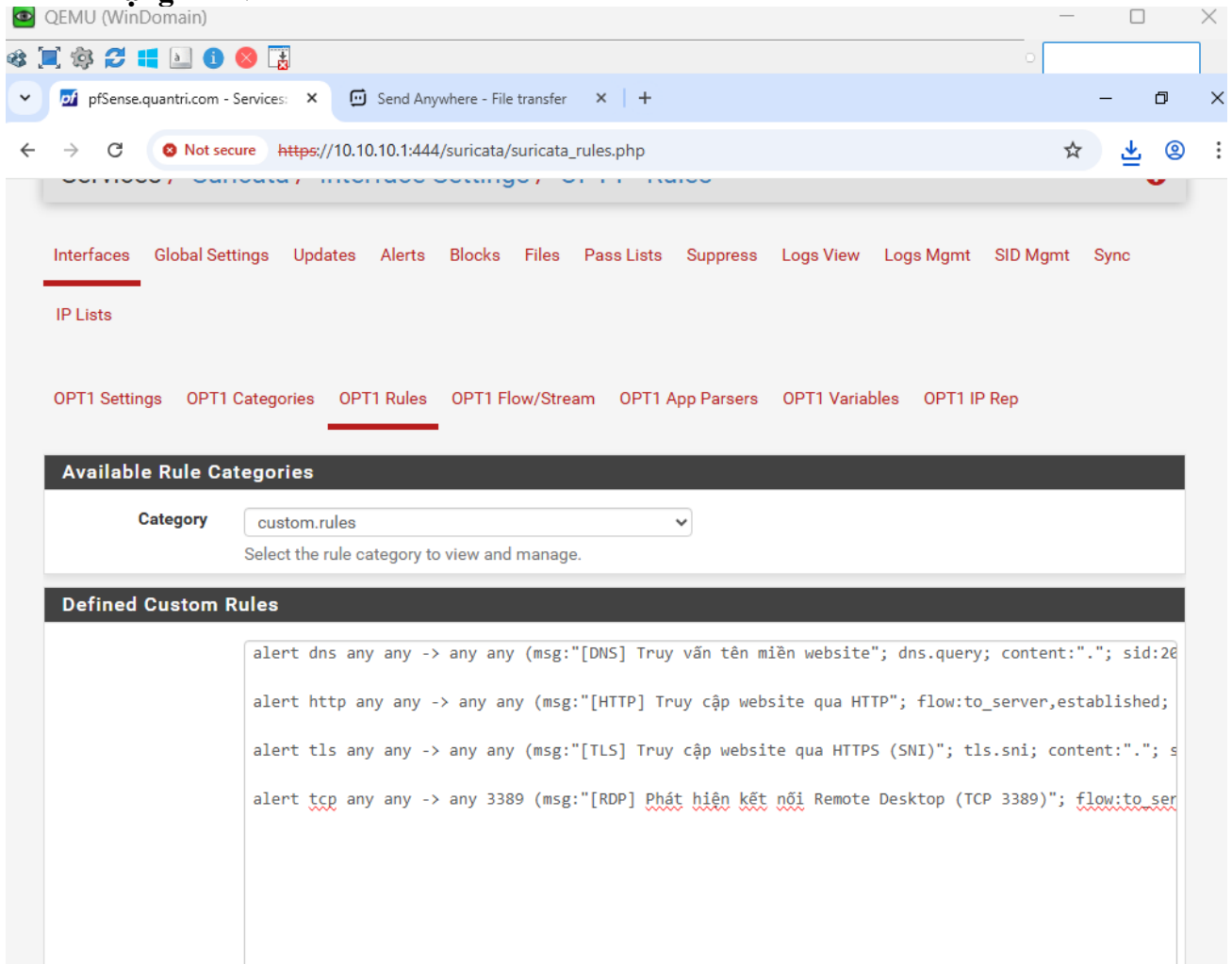
Hình 15. Người dùng vlan40 không cho ra internet thành công

4. Viét Rule Snort



Hình 16. Tích chọn các rule đã tải về từ snort community để tích hợp phát hiện ngăn chặn cho cổng wan

5. Viết Rule cho Pfsense từ Snort để kiểm soát mạng các thiết bị trong mạng LAN



Hình 17. Rules cho mạng LAN để kiểm tra mạng LAN đang truy

6. Cài đặt system endpoint (hip ossec)

Bước 1: cập nhật hệ thống

```

Select root@ubuntu: ~
Microsoft Windows [Version 10.0.26100.4652]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32>ssh root@192.168.32.170
The authenticity of host '192.168.32.170 (192.168.32.170)' can't be established.
ED25519 key fingerprint is SHA256:Z05W84qVXFT0T065BwwJnfCS9Z0YYot5jWFQz4RUq0M.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.32.170' (ED25519) to the list of known hosts.
root@192.168.32.170's password:
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.8.0-36-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

220 packages can be updated.
122 updates are security updates.

Last login: Tue Jun 20 15:35:14 2017 from 10.0.0.99
root@ubuntu:~# sudo apt update && sudo apt upgrade -y
Hit:1 http://cn.archive.ubuntu.com/ubuntu xenial InRelease
Get:2 http://security.ubuntu.com/ubuntu xenial-security InRelease [106 kB]
Get:3 http://cn.archive.ubuntu.com/ubuntu xenial-updates InRelease [106 kB]

```

Bước 2: cài đặt các gói

```

done
root@ubuntu:~# sudo apt install build-essential libssl-dev libevent-dev zlib1g-dev libpcap-dev libsystemd-dev -y
Reading package lists... Done
Building dependency tree
Reading state information... Done
build-essential is already the newest version (12.1ubuntu2).
The following packages were automatically installed and are no longer required:
  snap-confine snapd-login-service

```

Bước 3: cài đặt ossec

```

root@ubuntu:~#
root@ubuntu:~# wget https://github.com/ossec/ossec-hids/archive/refs/tags/3.7.0.tar.gz
--2025-07-19 20:02:25-- https://github.com/ossec/ossec-hids/archive/refs/tags/3.7.0.tar.gz
Resolving github.com (github.com)... 20.205.243.166
Connecting to github.com (github.com)|20.205.243.166|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://codeload.github.com/ossec/ossec-hids/tar.gz/refs/tags/3.7.0 [following]
--2025-07-19 20:02:35-- https://codeload.github.com/ossec/ossec-hids/tar.gz/refs/tags/3.7.0
Resolving codeload.github.com (codeload.github.com)... 20.205.243.165
Connecting to codeload.github.com (codeload.github.com)|20.205.243.165|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [application/x-gzip]
Saving to: '3.7.0.tar.gz'

3.7.0.tar.gz          [          <=>          ]  2.40M  1.50MB/s   in 1.
2025-07-19 20:02:37 (1.50 MB/s) - '3.7.0.tar.gz' saved [2518737]

```

Bước 4: setup ossec

```
root@ubuntu: ~/ossec-hids-3.7.0
install -m 0750 -o ossecr -g ossec -d /var/ossec/queue/rids
install -m 0640 -o root -g ossec ../etc/decoder.xml /var/ossec/etc/
rm -f /var/ossec/etc/shared/merged.mg

- System is Debian (Ubuntu or derivative).
- Init script modified to start OSSEC HIDS during boot.

- Configuration finished properly.

- To start OSSEC HIDS:
  /var/ossec/bin/ossec-control start

- To stop OSSEC HIDS:
  /var/ossec/bin/ossec-control stop

- The configuration can be viewed or modified at /var/ossec/etc/ossec.conf

Thanks for using the OSSEC HIDS.
If you have any question, suggestion or if you find any bug,
contact us at https://github.com/ossec/ossec-hids or using
our public maillist at
https://groups.google.com/forum/#!forum/ossec-list

More information can be found at http://www.ossec.net

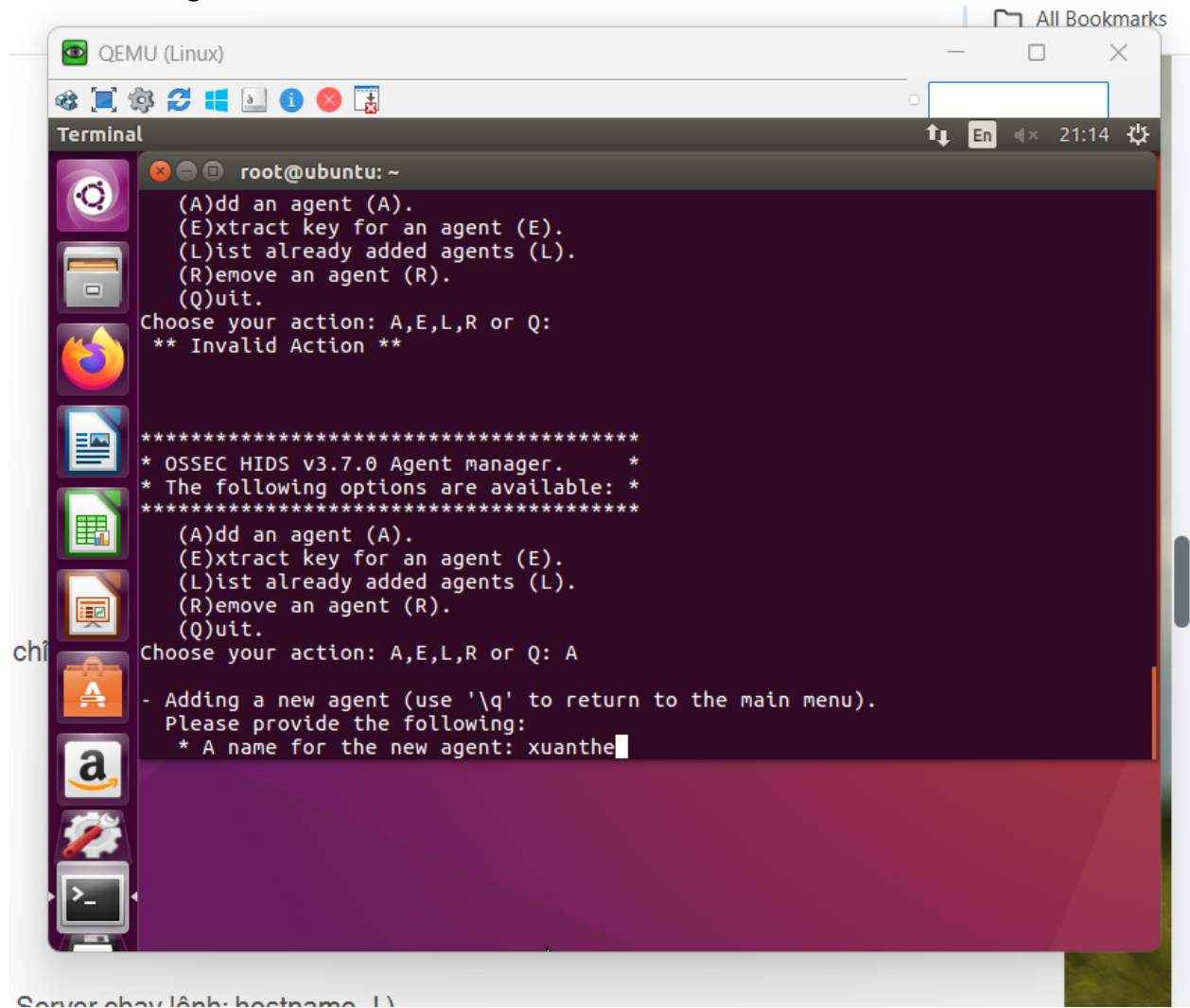
--- Press ENTER to finish (maybe more information below). ---
```

Bước 5: khởi động ossec và kiểm tra trạng thái

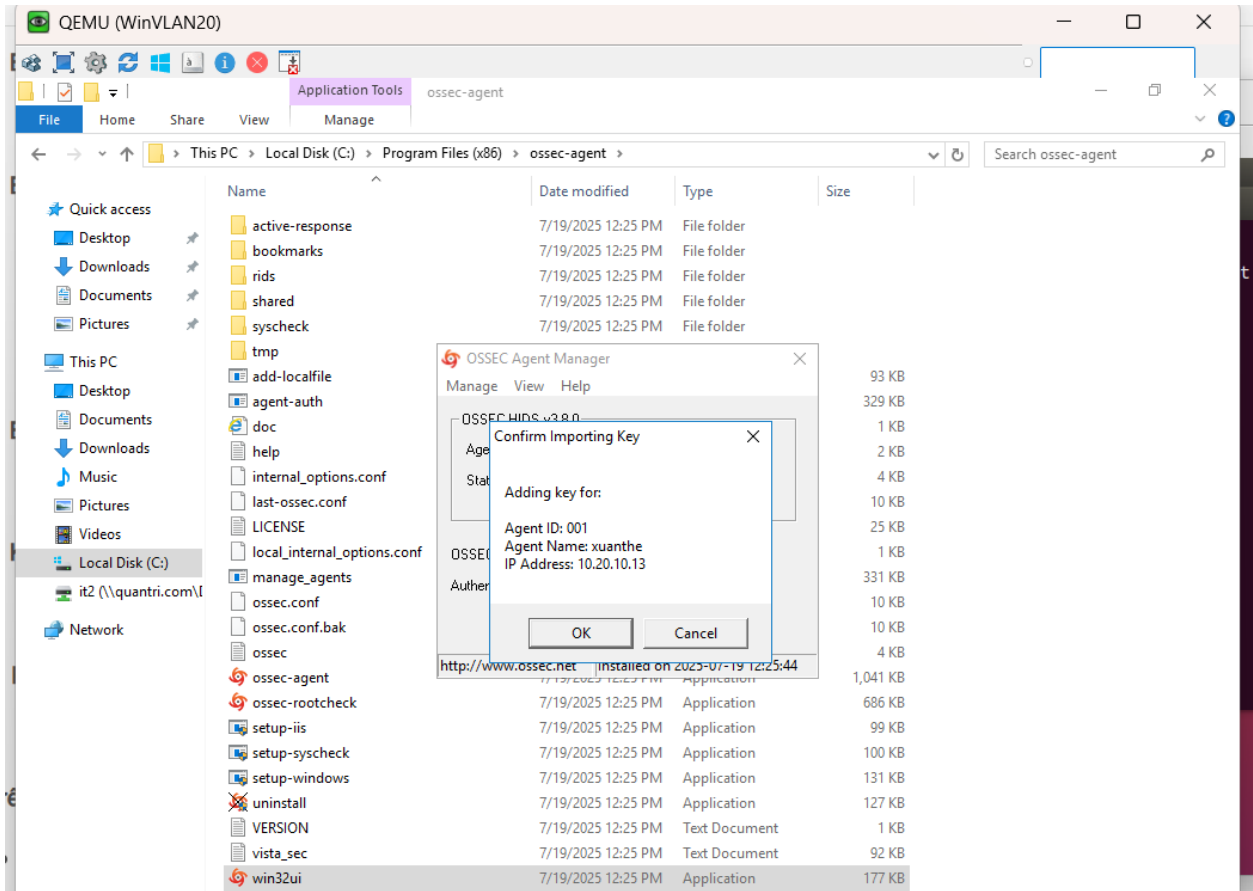
```
http://www.ossec.net/docs/docs/programs/manage_agents.html
root@ubuntu:~/ossec-hids-3.7.0# sudo /var/ossec/bin/ossec-control start
Starting OSSEC HIDS v3.7.0...
Started ossec-execd...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-remoted...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
root@ubuntu:~/ossec-hids-3.7.0# sudo /var/ossec/bin/ossec-control status
ossec-monitord is running...
ossec-logcollector is running...
ossec-remoted: Process 3483 not used by ossec, removing ..
ossec-remoted not running...
ossec-syscheckd is running...
ossec-analysisd is running...
ossec-execd is running...
root@ubuntu:~/ossec-hids-3.7.0#
```

q dẫn mặc định

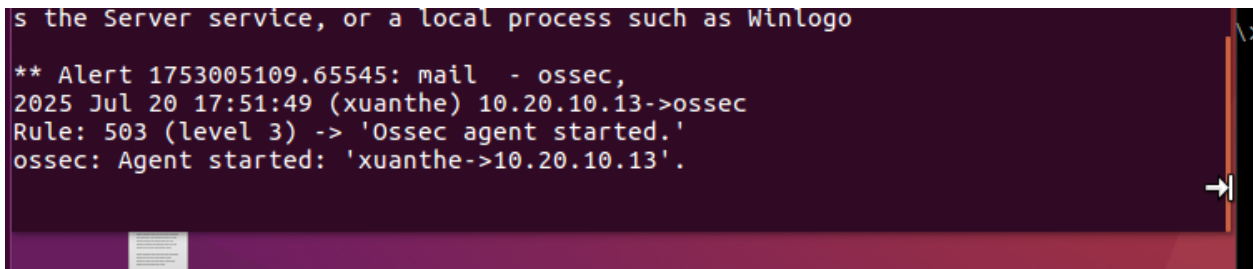
Bước 6: tạo agent mới



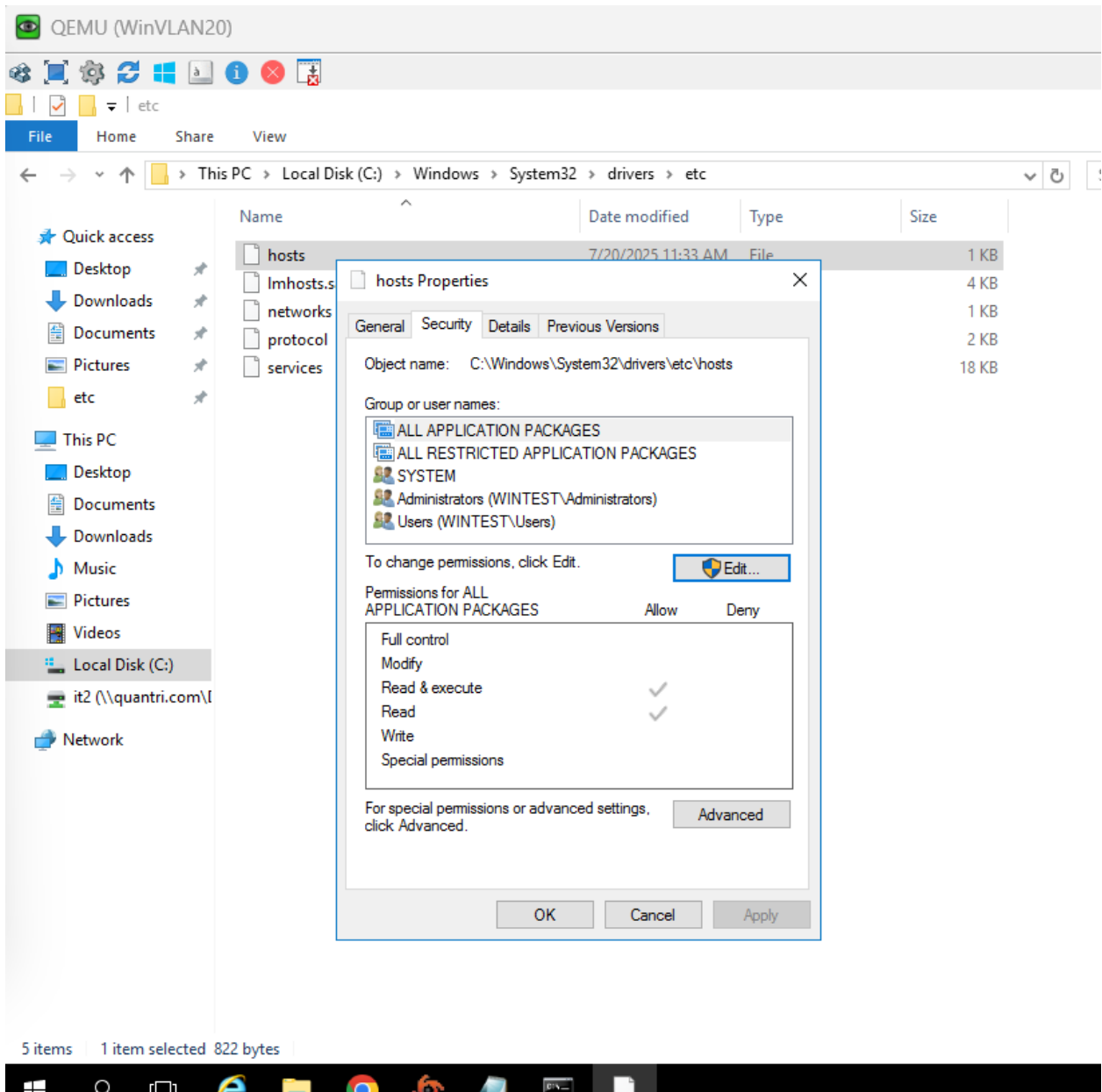
Bước 7: tạo key và thêm vào window ossec



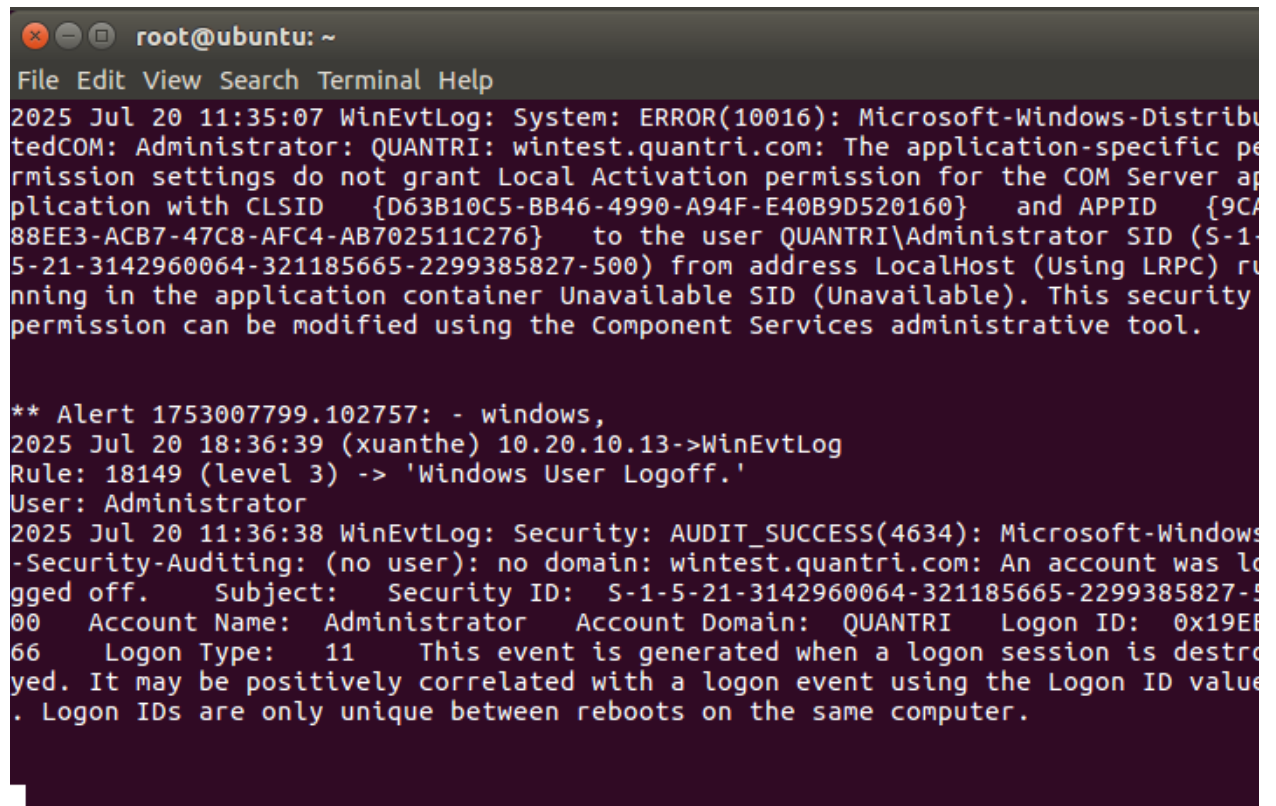
Bước 8: kết nối thành công



Bước 11: thử trong trường hợp user muốn thay đổi quyền 1 thư mục nào đó và biết được pass của admin



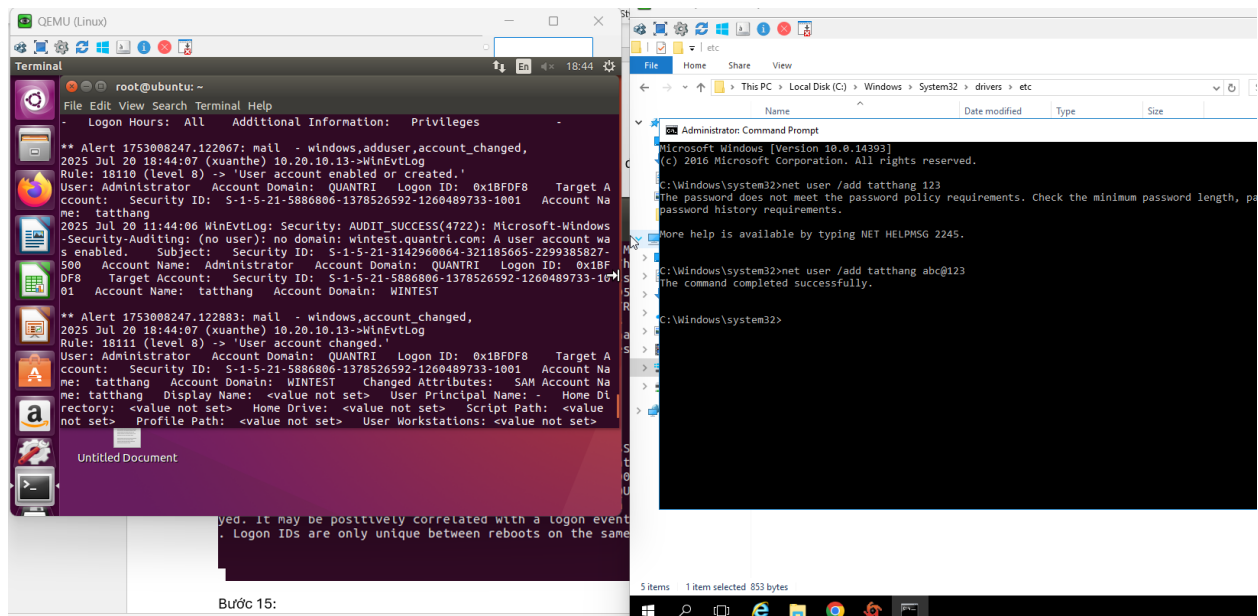
Bước 12: xem log cho thấy user xuanthe vừa logoff và thay vào đó là user Admin vừa đăng nhập vào

A terminal window titled 'root@ubuntu: ~' with a menu bar 'File Edit View Search Terminal Help'. The terminal displays two Windows Event Log messages. The first is a System error (10016) from WinEvtLog, dated 2025 Jul 20 11:35:07, describing a permission issue for a COM application. The second is an Audit Success (4634) message from WinEvtLog, dated 2025 Jul 20 11:36:38, indicating that the Administrator account was logged off. A third line shows a logon event from xuanthe at 18:36:39, which is partially cut off.

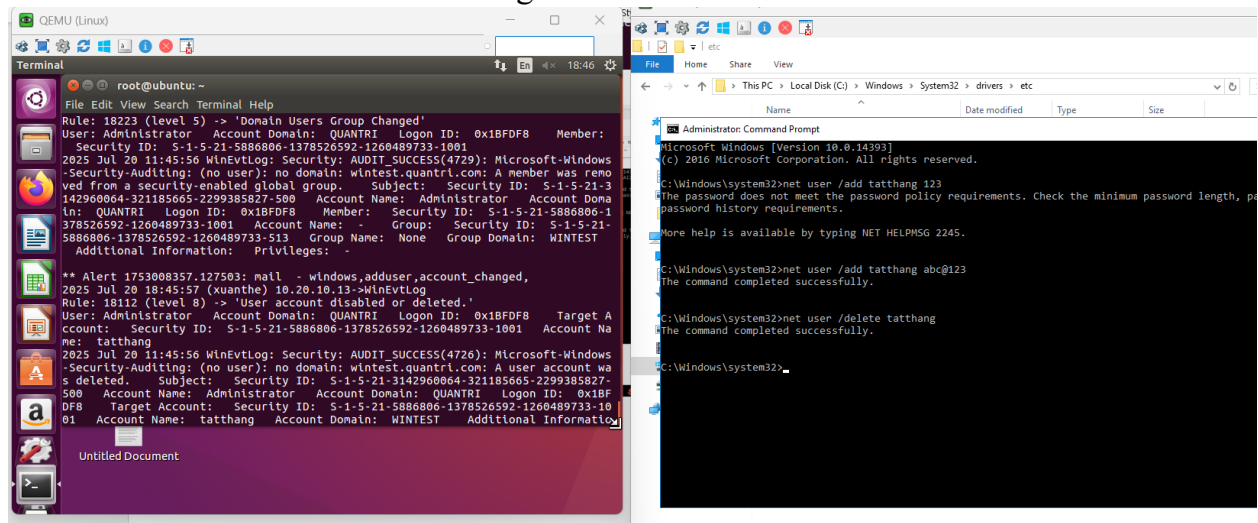
```
root@ubuntu: ~
File Edit View Search Terminal Help
2025 Jul 20 11:35:07 WinEvtLog: System: ERROR(10016): Microsoft-Windows-Distribu
tedCOM: Administrator: QUANTRI: wintest.quantri.com: The application-specific pe
rmission settings do not grant Local Activation permission for the COM Server ap
plication with CLSID {D63B10C5-BB46-4990-A94F-E40B9D520160} and APPID {9CA
88EE3-ACB7-47C8-AFC4-AB702511C276} to the user QUANTRI\Administrator SID (S-1-
5-21-3142960064-321185665-2299385827-500) from address LocalHost (Using LRPC) ru
nning in the application container Unavailable SID (Unavailable). This security
permission can be modified using the Component Services administrative tool.

** Alert 1753007799.102757: - windows,
2025 Jul 20 18:36:39 (xuanthe) 10.20.10.13->WinEvtLog
Rule: 18149 (level 3) -> 'Windows User Logoff.'
User: Administrator
2025 Jul 20 11:36:38 WinEvtLog: Security: AUDIT_SUCCESS(4634): Microsoft-Windows
-Security-Auditing: (no user): no domain: wintest.quantri.com: An account was lo
gged off. Subject: Security ID: S-1-5-21-3142960064-321185665-2299385827-5
00 Account Name: Administrator Account Domain: QUANTRI Logon ID: 0x19E
66 Logon Type: 11 This event is generated when a logon session is destr
oyed. It may be positively correlated with a logon event using the Logon ID value
. Logon IDs are only unique between reboots on the same computer.
```

Bước 13: test thử thêm user và xem log



Bước 14: test thử xóa user và xem log

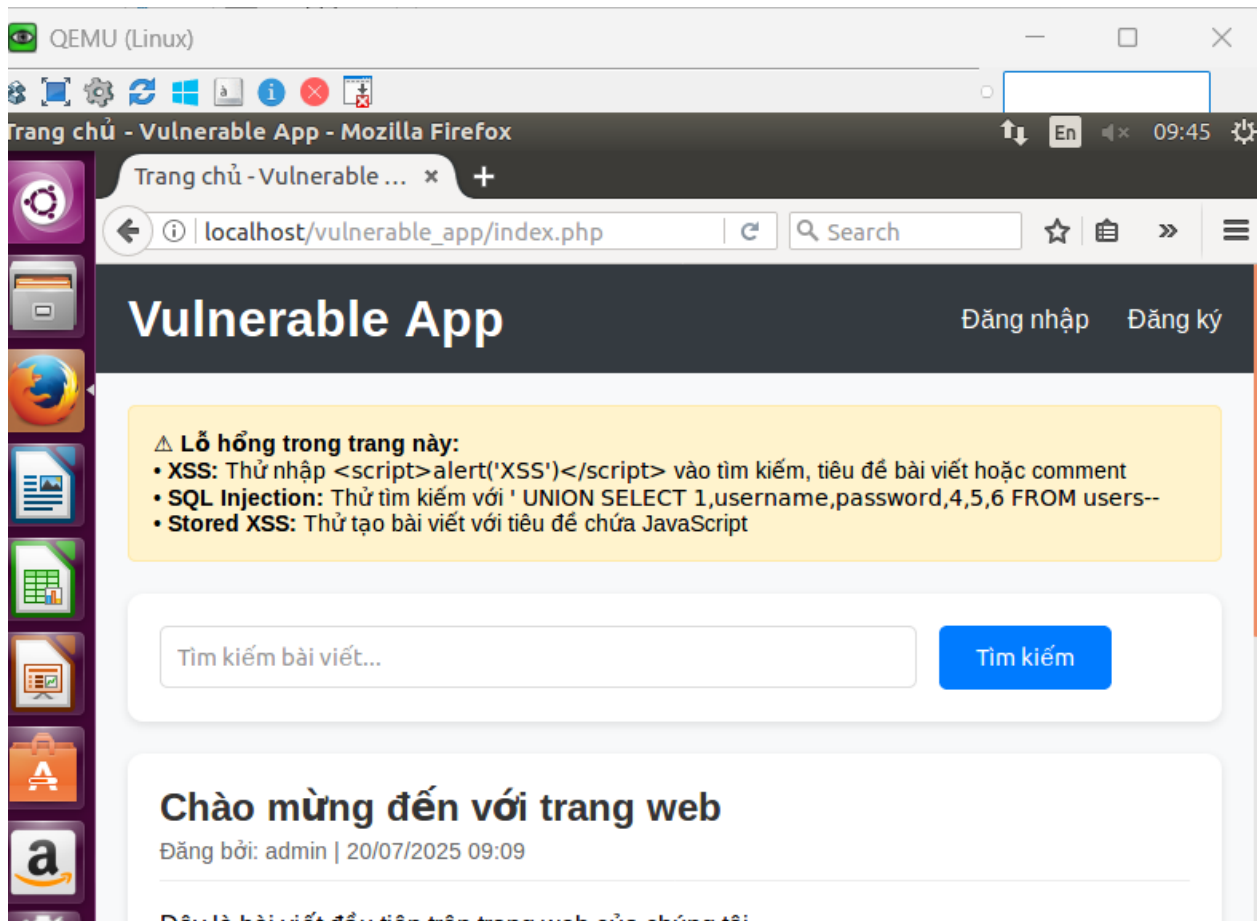


7. Cài đặt demo 3 case tấn công:

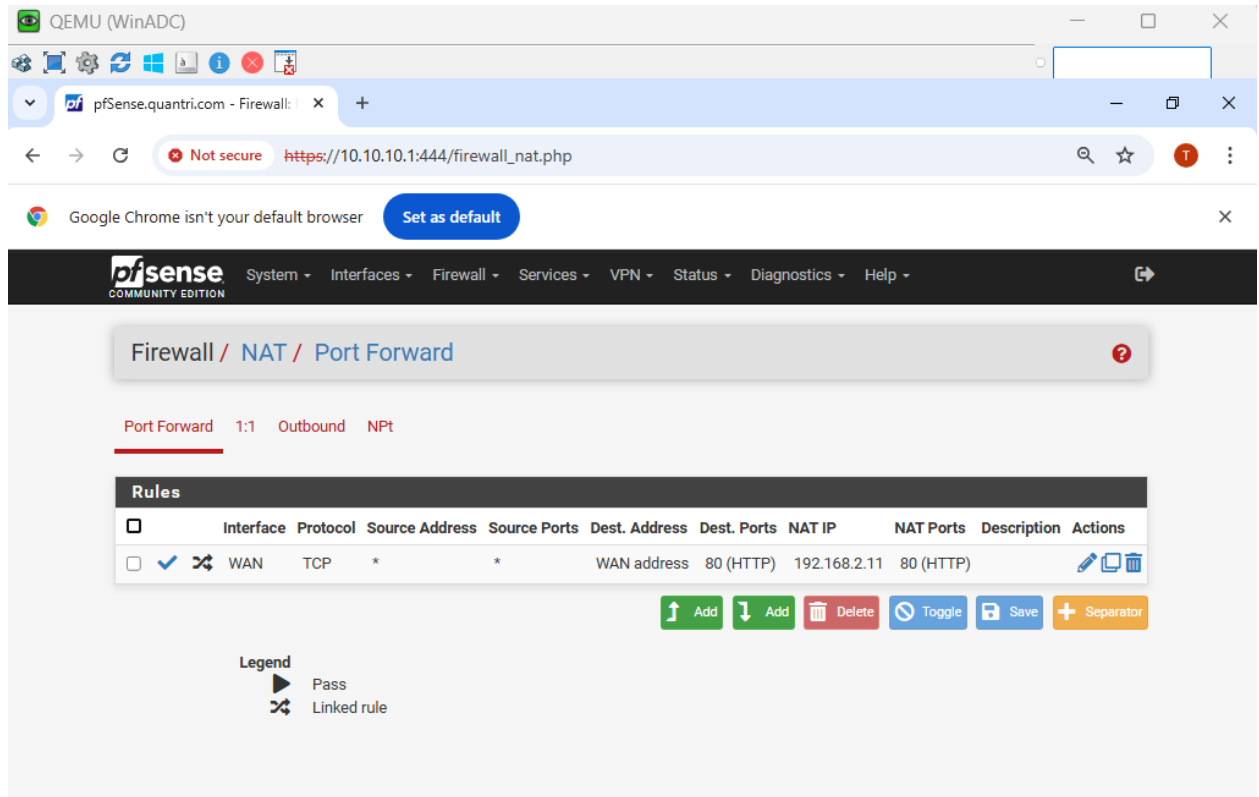
7.1 Tấn công thu thập thông tin và bruteforce ssh

(kịch bản sẽ là hacker dùng nmap sau đó phát hiện các cổng mở, từ đó tấn công vào cổng ssh đó)

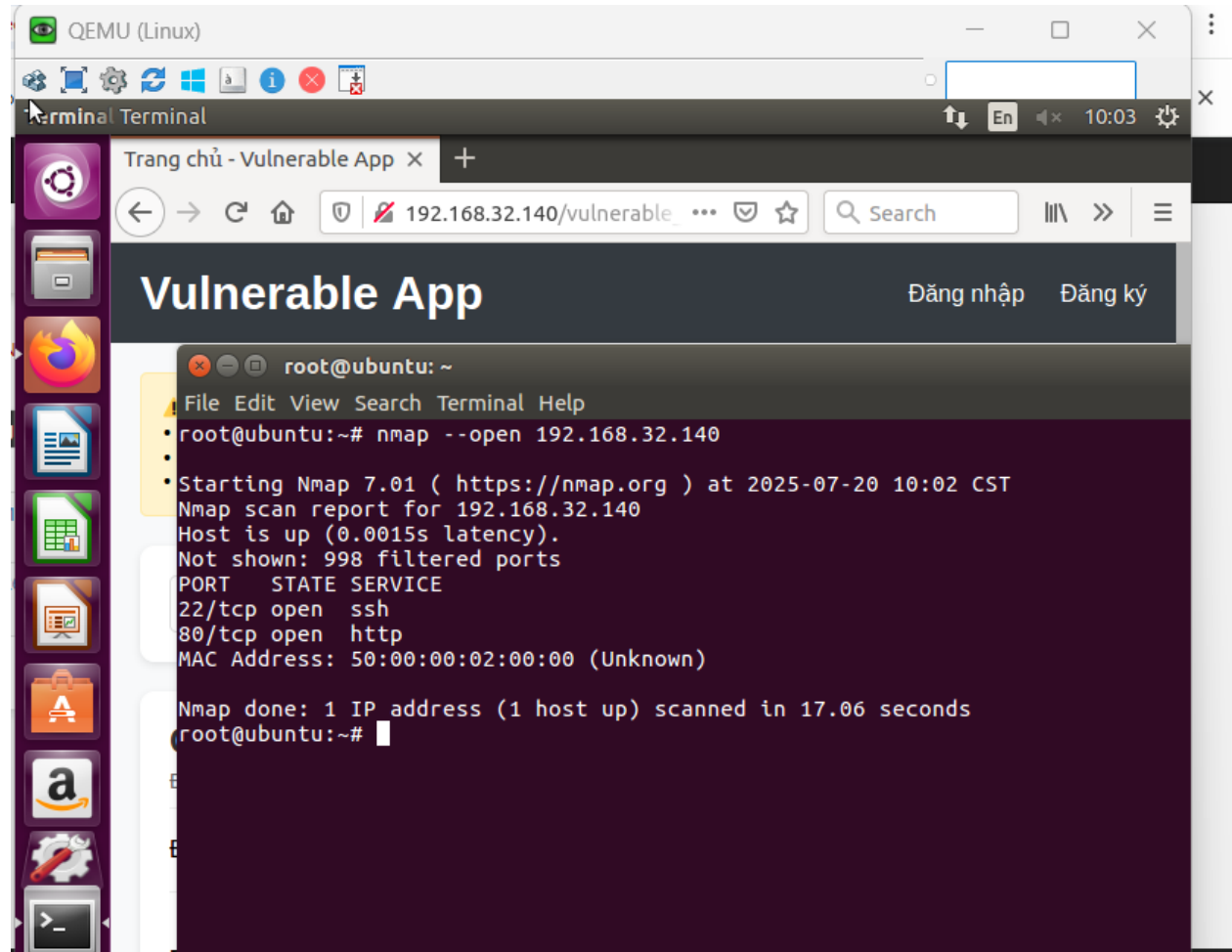
Bước 1: cài đặt và chạy được webapache trên ubuntu



Bước 2: nat địa chỉ của winpublic ra cổng wan của pfsense để cho phép truy cập từ bên ngoài



Bước 3: để hacker thử truy cập và scan nmap xem các cổng đang mở

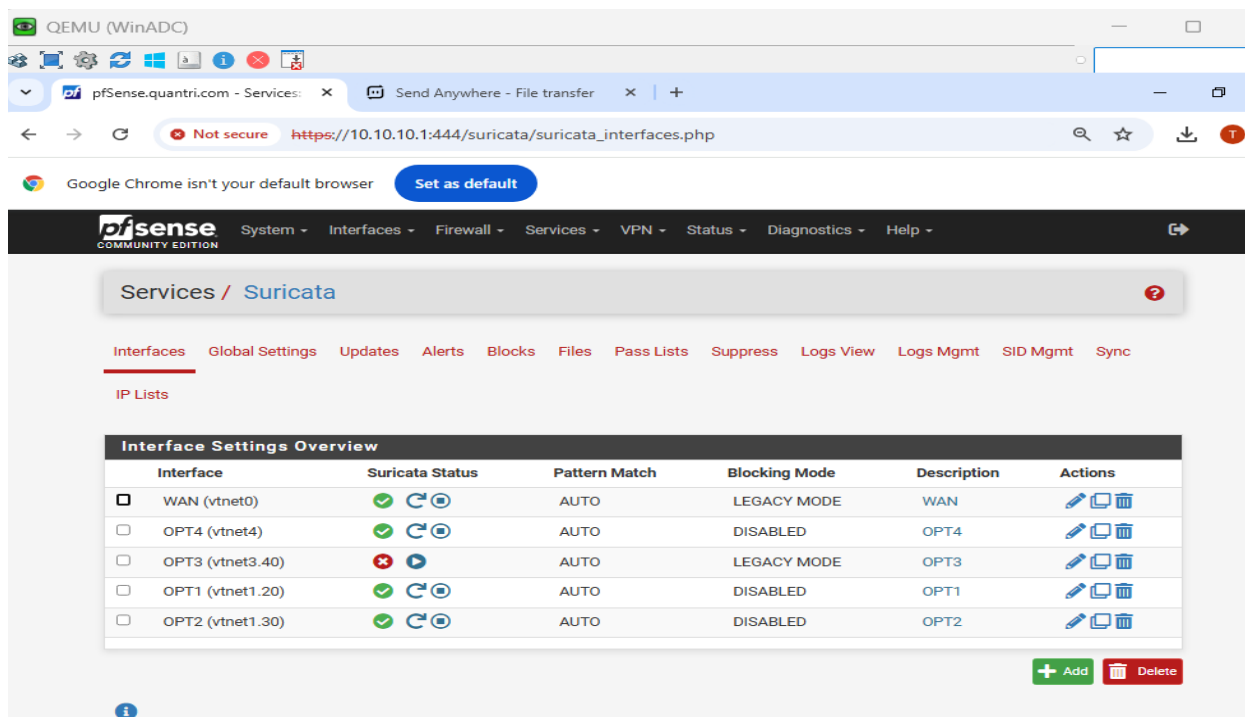


Bước 4: khi hacker biết được có cổng ssh đang mở, tiến hành tấn công bruteforce

```
root@ubuntu:~# hydra -l root -P pass.txt ssh://192.168.32.140
Hydra v8.1 (c) 2014 by van Hauser/THC - Please do not use in military or secret
service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2025-07-20 10:18:48
[WARNING] Many SSH configurations limit the number of parallel tasks, it is rec
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 64 tasks, 21 login tries (l:1/p:21),
0 tries per task
[DATA] attacking service ssh on port 22
[22][ssh] host: 192.168.32.140 login: root password: eve@123
[STATUS] attack finished for 192.168.32.140 (waiting for children to finish) ..
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2025-07-20 10:19:00
root@ubuntu:~#
```

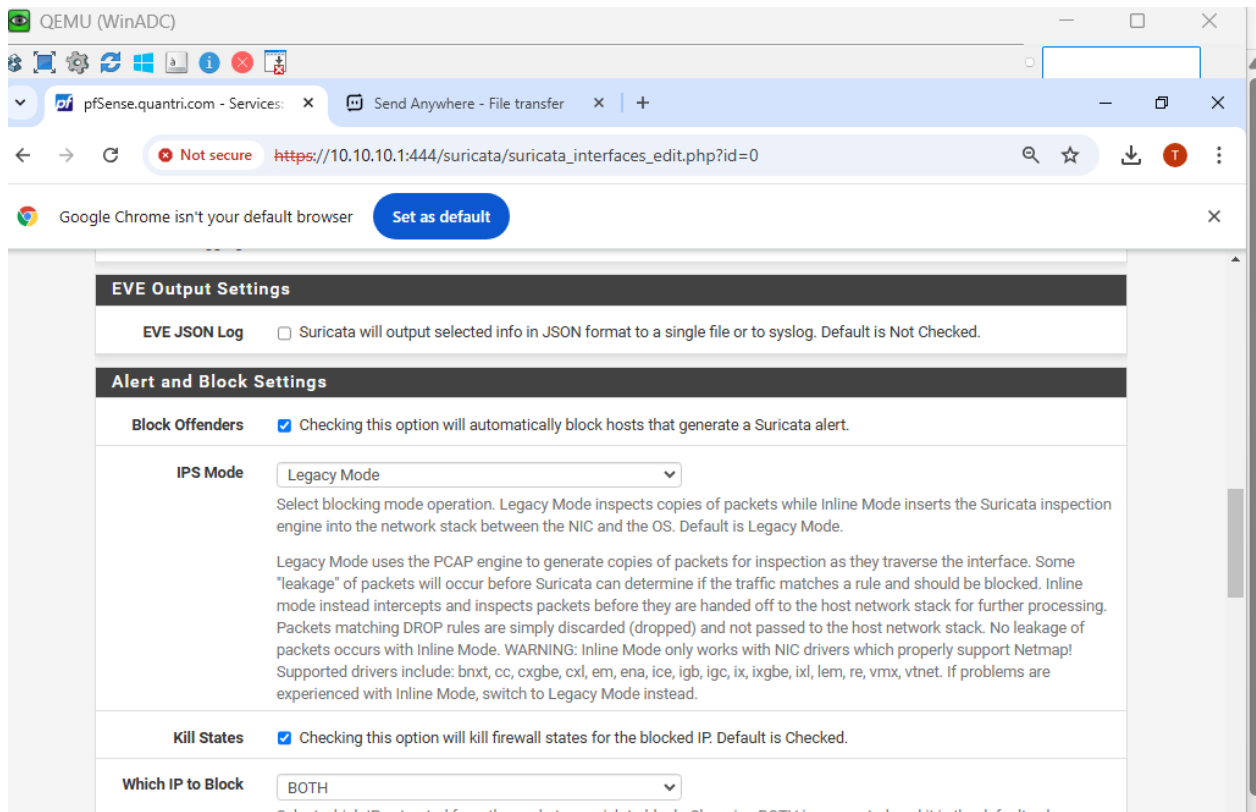
Bước 5: tiến hành khởi động chế độ giám sát và ngăn chặn (ips trên cổng wan để tự động phát hiện và ngăn chặn)



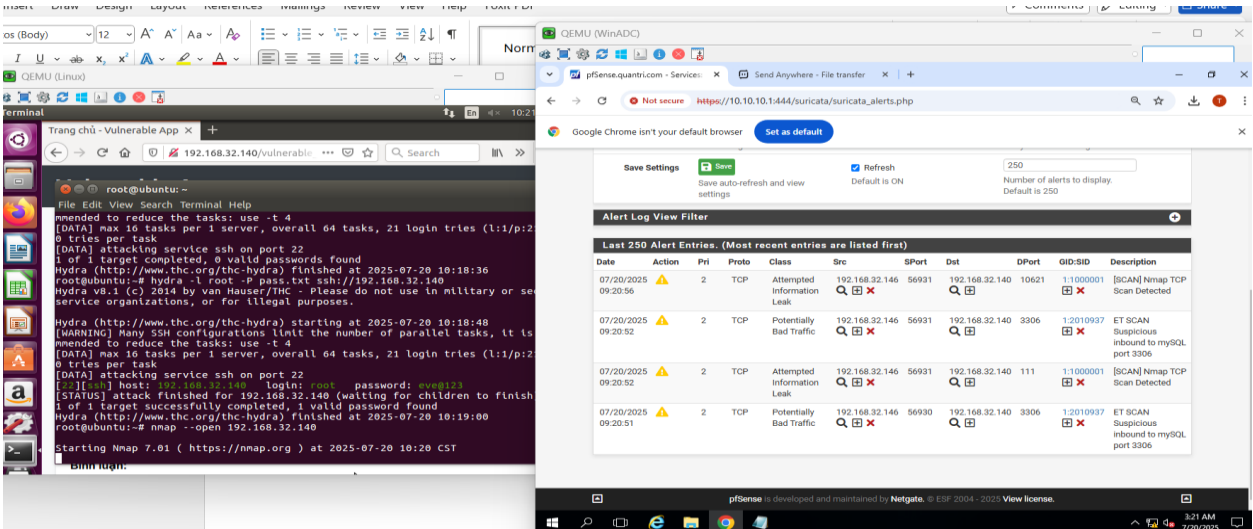
The screenshot shows the pfSense web interface for Suricata. The browser address bar indicates the URL is https://10.10.10.1:444/suricata/suricata_interfaces.php. The interface has a navigation bar with links: System, Interfaces, Firewall, Services, VPN, Status, Diagnostics, and Help. The main content area is titled "Services / Suricata" and includes a sub-menu with "Interfaces" (selected), Global Settings, Updates, Alerts, Blocks, Files, Pass Lists, Suppress, Logs View, Logs Mgmt, SID Mgmt, and Sync. Below the sub-menu is the "Interface Settings Overview" table.

Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☐ WAN (vtnet0)		AUTO	LEGACY MODE	WAN	
☐ OPT4 (vtnet4)		AUTO	DISABLED	OPT4	
☐ OPT3 (vtnet3.40)		AUTO	LEGACY MODE	OPT3	
☐ OPT1 (vtnet1.20)		AUTO	DISABLED	OPT1	
☐ OPT2 (vtnet1.30)		AUTO	DISABLED	OPT2	

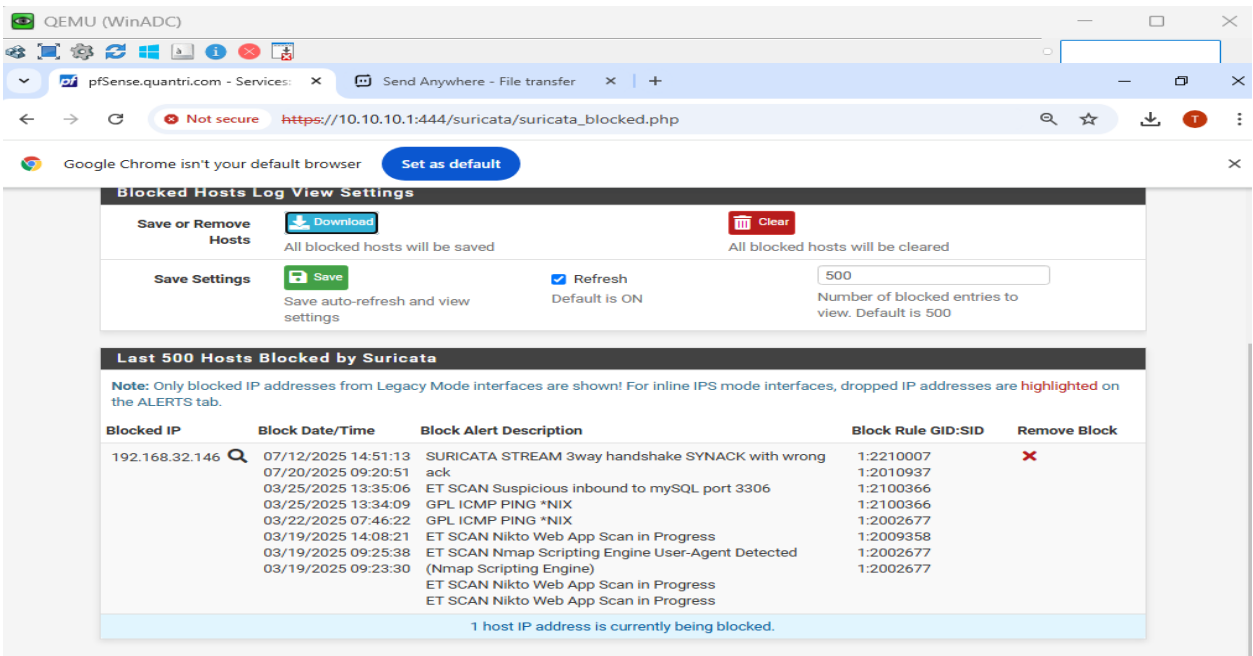
At the bottom right of the table, there are buttons for "+ Add" and "Delete".



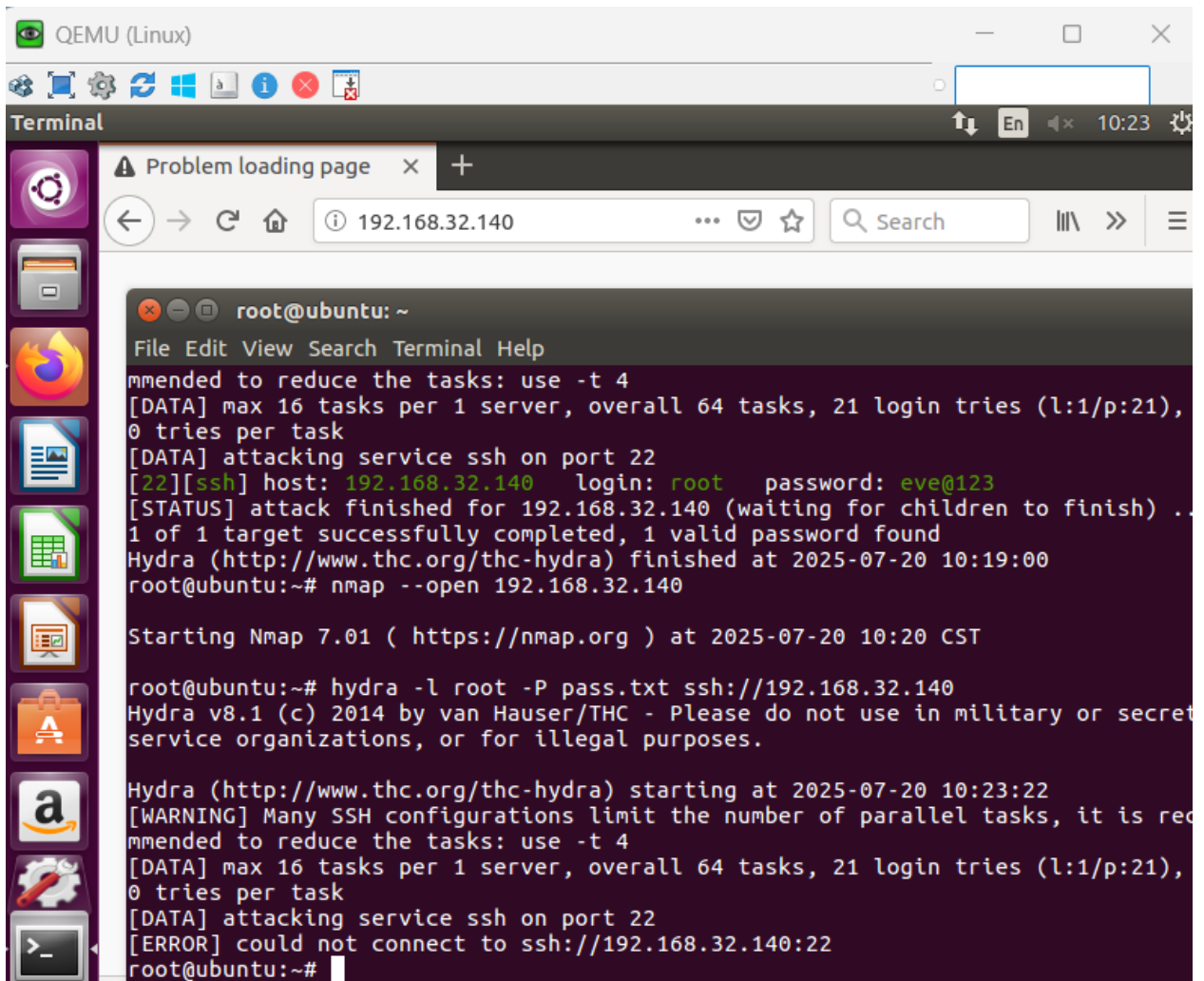
Bước 5:hacker tiến hành quét nmap và bruteforce ssh lại(trên pfSEN cũng đã phát hiện và gửi alert



Bước 6: xem mục block ta thấy pfSense đã chặn ip của hacker



Bước 7: vì hacker đã bị chặn nên việc truy cập trang web và bruteforce ssh trở nên bất khả thi



```
QEMU (Linux)
Terminal
Problem loading page x +
192.168.32.140
root@ubuntu: ~
File Edit View Search Terminal Help
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 64 tasks, 21 login tries (l:1/p:21),
0 tries per task
[DATA] attacking service ssh on port 22
[22][ssh] host: 192.168.32.140 login: root password: eve@123
[STATUS] attack finished for 192.168.32.140 (waiting for children to finish) ..
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2025-07-20 10:19:00
root@ubuntu:~# nmap --open 192.168.32.140

Starting Nmap 7.01 ( https://nmap.org ) at 2025-07-20 10:20 CST

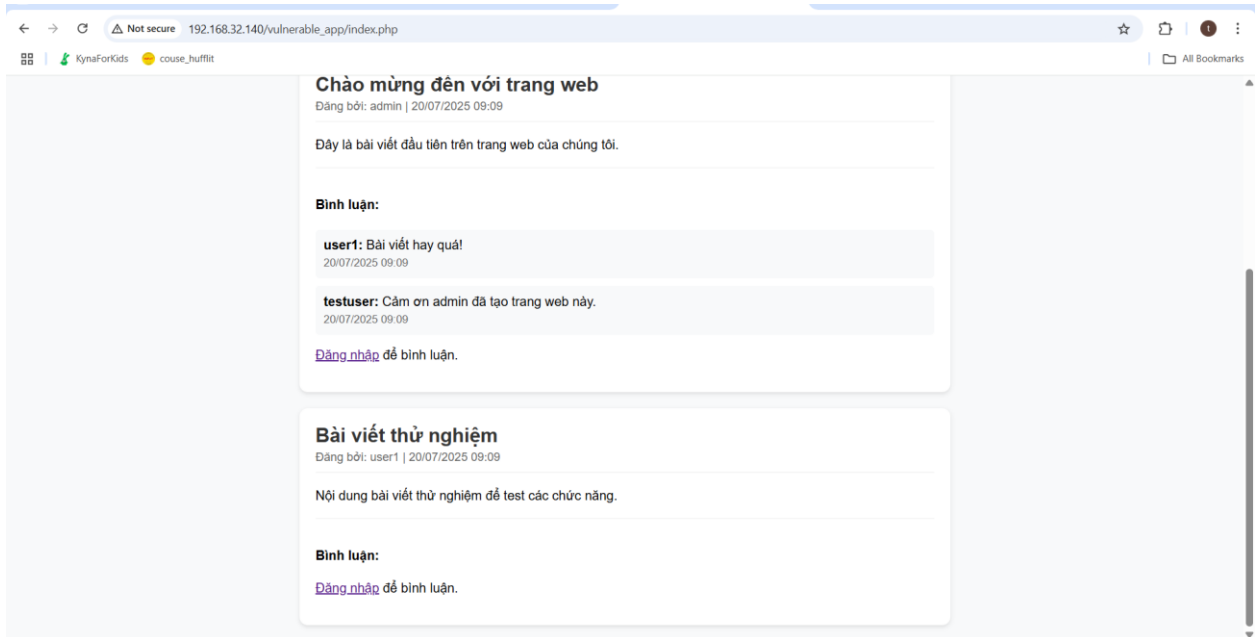
root@ubuntu:~# hydra -l root -P pass.txt ssh://192.168.32.140
Hydra v8.1 (c) 2014 by van Hauser/THC - Please do not use in military or secret
service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2025-07-20 10:23:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is rec
mmended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 64 tasks, 21 login tries (l:1/p:21),
0 tries per task
[DATA] attacking service ssh on port 22
[ERROR] could not connect to ssh://192.168.32.140:22
root@ubuntu:~#
```

7.2 Demo tấn công sql injection

(kịch bản sẽ là hacker sẽ truy cập web và thử các lệnh union để đánh cắp thông tin)

Đầu tiên hacker truy cập vào trang web



Bước 1: giả sử hacker đã mò được cấu trúc của bảng user

```

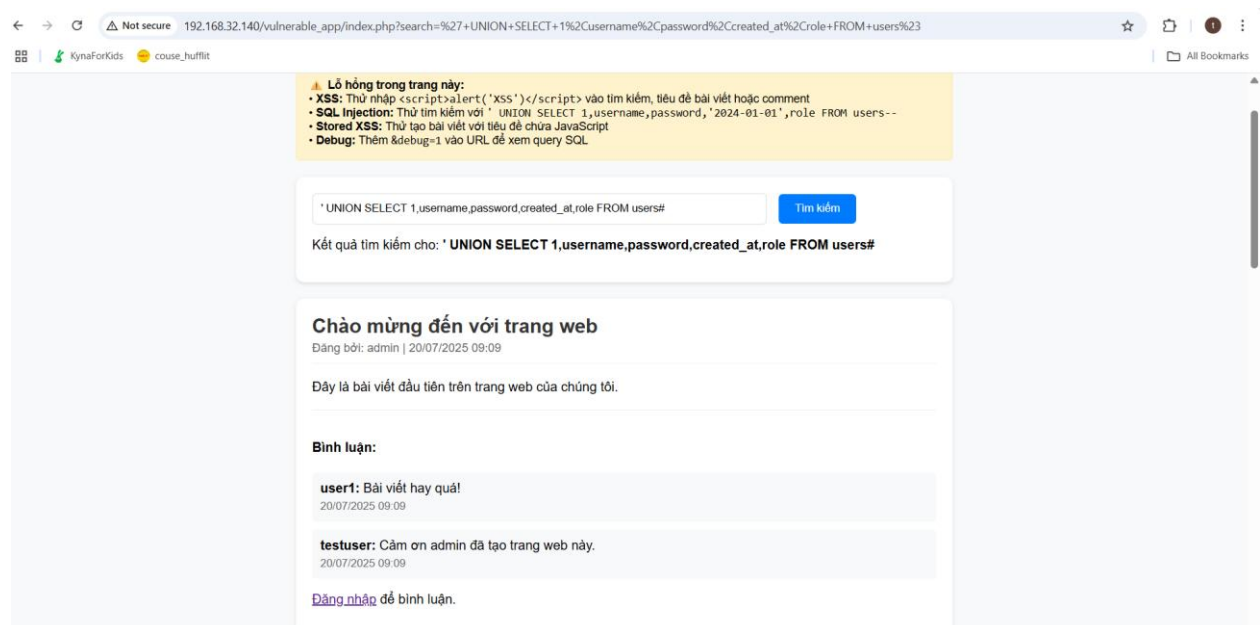
root@ubuntu: ~
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| vulnerable_app |
+-----+
4 rows in set (0.00 sec)

MariaDB [(none)]> use vulnerable_app
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

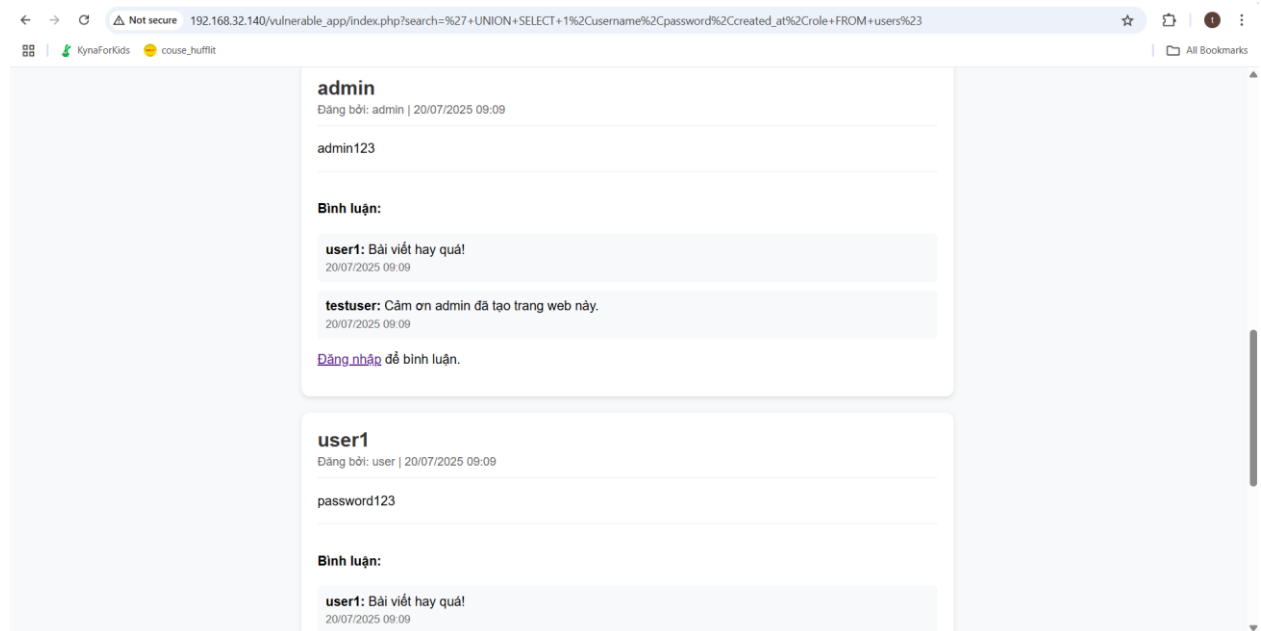
Database changed
MariaDB [vulnerable_app]> describe users;
+-----+-----+-----+-----+-----+-----+
| Field | Type | Null | Key | Default | Extra |
+-----+-----+-----+-----+-----+-----+
| id | int(11) | NO | PRI | NULL | auto_increment |
| username | varchar(50) | NO | UNI | NULL |
| email | varchar(100) | NO | | NULL |
| password | varchar(255) | NO | | NULL |
| full_name | varchar(100) | YES | | NULL |
| role | varchar(20) | YES | | user |
| created_at | timestamp | NO | | CURRENT_TIMESTAMP |
| last_login | timestamp | YES | | NULL |
+-----+-----+-----+-----+-----+-----+
8 rows in set (0.00 sec)

MariaDB [vulnerable_app]>
  
```

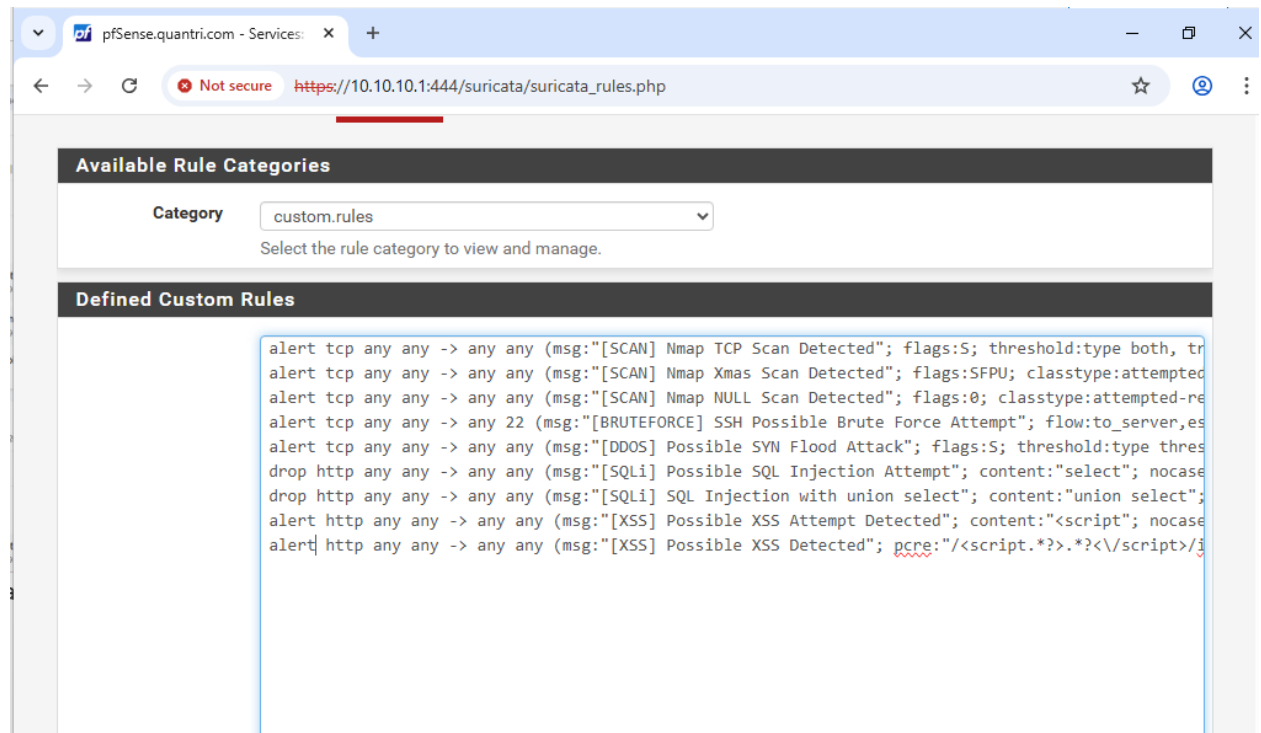
Bước 2: hacker bắt đầu câu lệnh union để xem các user có trong bảng và mật khẩu



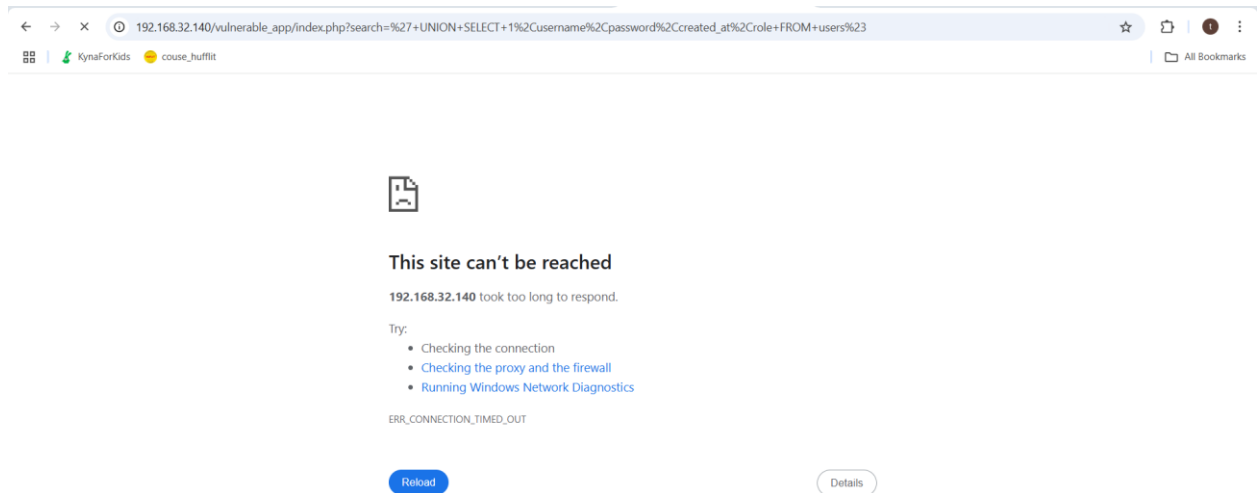
Bước 3: hacker đã xem được các người dùng và mật khẩu của họ



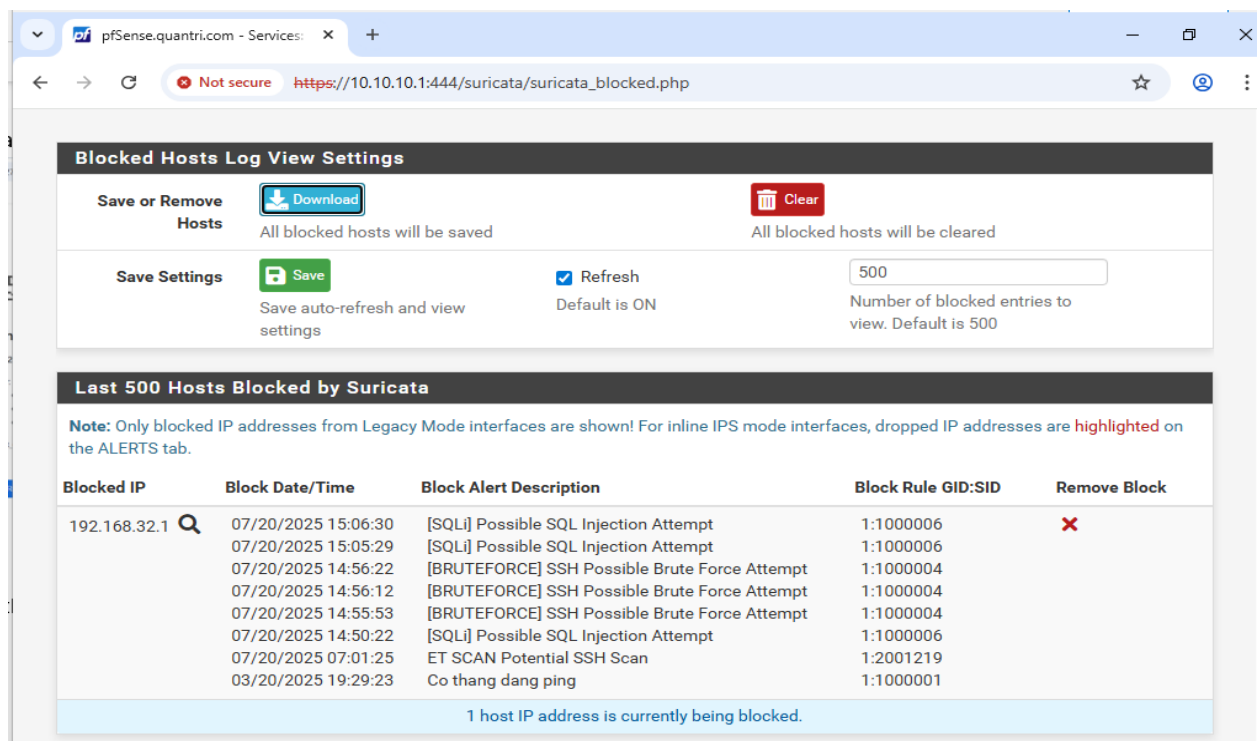
Bước 4: ta sẽ đổi các rule từ alert sang drop để câu lệnh bị chặn ngay từ lúc chạy



Bước 5: hacker bắt đầu thử lại lệnh union, không thể truy cập vào trang



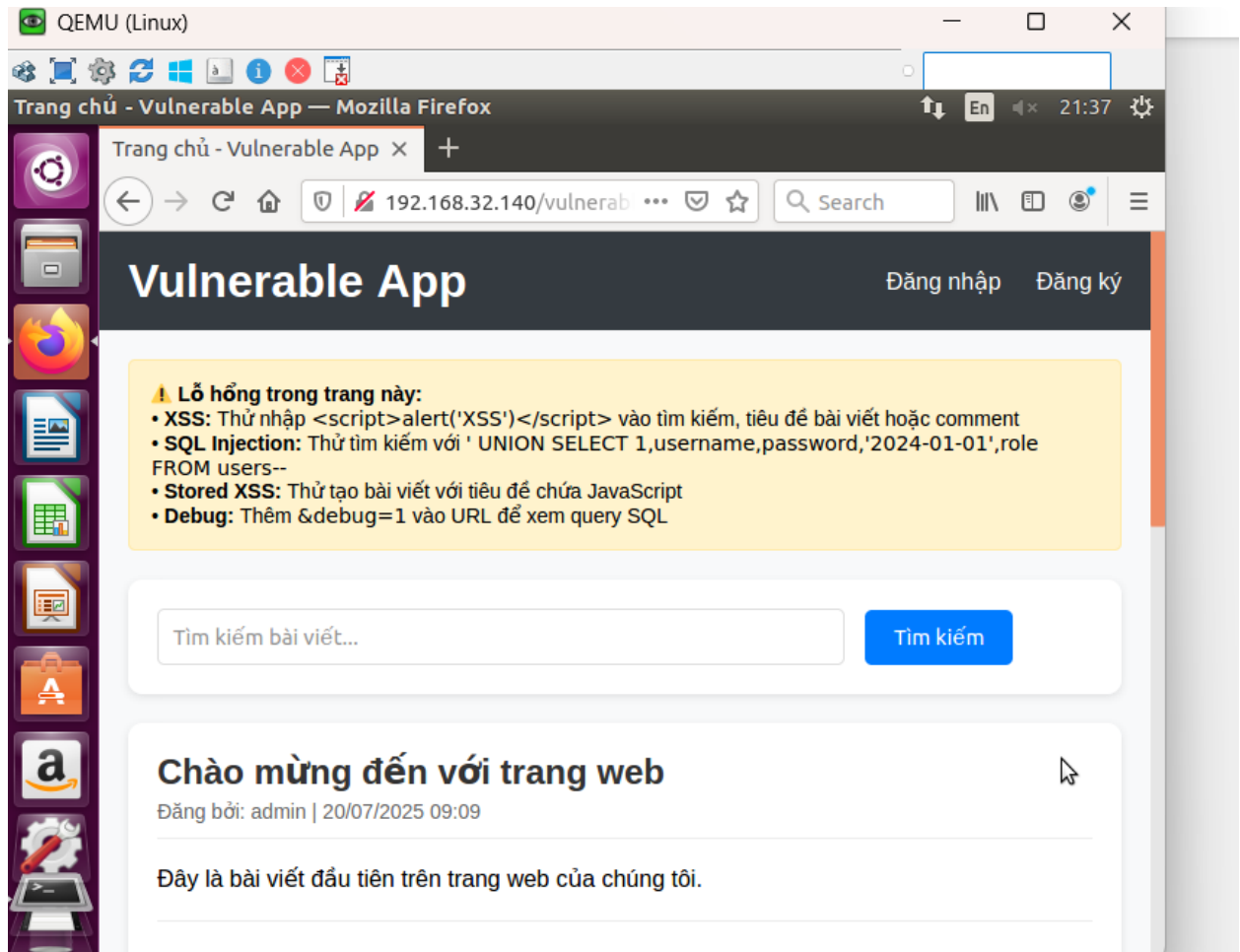
Bước 6: vào xem block ta sẽ thấy suricata đã phát hiện tấn công và chặn ip của hacker



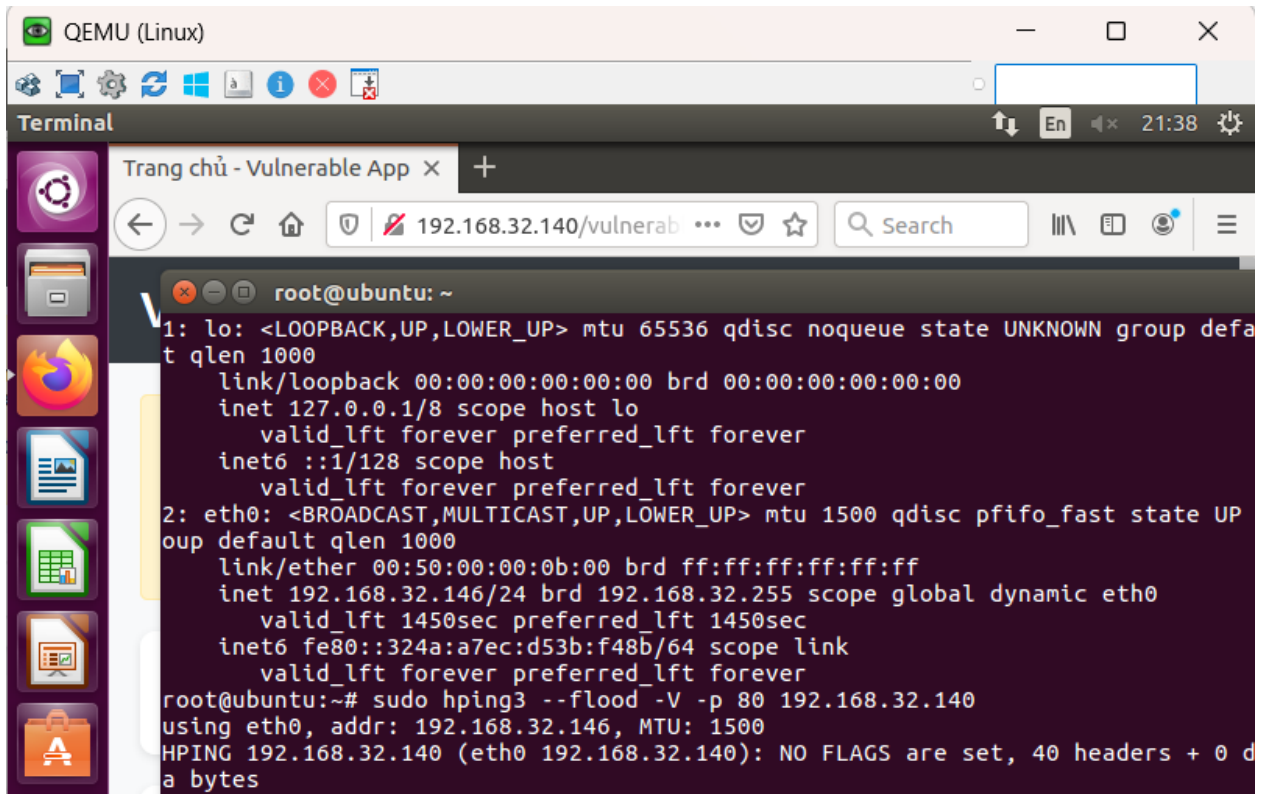
7.3 Demo tan cong ddos web

sudo hping3 -S --flood -V -p 80 192.168.32.140

Buoc 1: Hacker truy cập web như thường lệ để xem tình trạng của website



Bước 2: Khi biết được ip, hấn ta bắt đầu ddos trang web để đánh sập server



The screenshot shows a QEMU (Linux) terminal window. The terminal displays the output of the `ifconfig` command, showing the configuration for the loopback interface `lo` and the ethernet interface `eth0`. The `eth0` interface is configured with IP `192.168.32.146` and MTU `1500`. Below the network configuration, the user runs the command `sudo hping3 --flood -V -p 80 192.168.32.140`, which initiates a flood attack on the target IP `192.168.32.140` using port `80`. The output of the command shows that the attack is successful, with `NO FLAGS` set and `40 headers + 0 data bytes` sent.

```
QEMU (Linux)
Terminal
Trang chủ - Vulnerable App x +
192.168.32.140/vulnerab ...
root@ubuntu: ~
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group defa
t qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP
oup default qlen 1000
    link/ether 00:50:00:00:0b:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.32.146/24 brd 192.168.32.255 scope global dynamic eth0
        valid_lft 1450sec preferred_lft 1450sec
    inet6 fe80::324a:a7ec:d53b:f48b/64 scope link
        valid_lft forever preferred_lft forever
root@ubuntu:~# sudo hping3 --flood -V -p 80 192.168.32.140
using eth0, addr: 192.168.32.146, MTU: 1500
HPING 192.168.32.140 (eth0 192.168.32.140): NO FLAGS are set, 40 headers + 0 d
a bytes
```

Bước 3: Dưới đây là hình ảnh pfsense phải chịu trước và đang bị tấn công

Trước tấn công:

The screenshot displays the pfSense web interface within a QEMU (WinDomain) window. The browser address bar shows a 'Not secure' connection to <https://10.10.10.1:444>. The interface includes a top navigation bar with a pfSense logo and a 'Status' tab. The main content area is divided into several sections:

- System Status:** Displays the current date/time (Wed Jul 23 20:39:29 +07 2025), DNS server(s) (127.0.0.1, 8.8.8.8, 8.8.4.4, 208.67.222.222), Last config change (Wed Jul 23 20:14:15 +07 2025), State table size (0% (86/199000)), MBUF Usage (1% (1008/124042)), Load average (0.58, 0.67, 0.60), CPU usage (1%), Memory usage (39% of 1990 MiB), and SWAP usage (0% of 3071 MiB).
- Interfaces:** A table listing network interfaces and their status:

Interface	Status	Speed	Duplex	IP Address
WAN	Up	10Gbase-T	<full-duplex>	192.168.32.140
LAN	Up	10Gbase-T	<full-duplex>	10.10.10.1
OPT1	Up	10Gbase-T	<full-duplex>	10.20.10.1
OPT2	Up	10Gbase-T	<full-duplex>	10.30.10.1
OPT3	Up	10Gbase-T	<full-duplex>	192.168.2.1
OPT4	Up	10Gbase-T	<full-duplex>	192.168.10.1

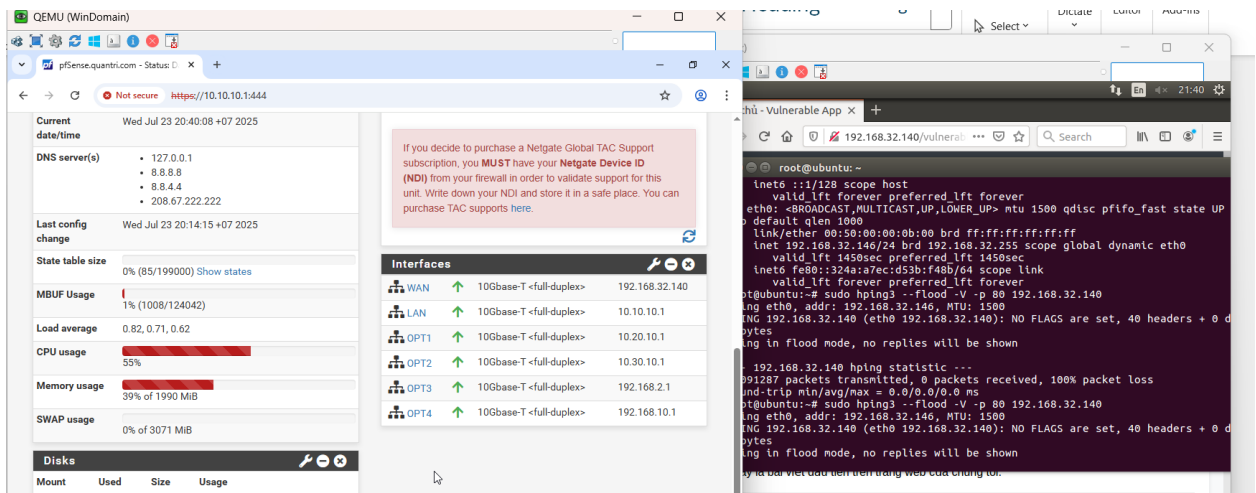
- Disks:** A table showing disk usage for the root filesystem:

Mount	Used	Size	Usage
/	2.6G	59G	5% of 59G (ufs)

A red banner at the top right of the interface contains the following text: "If you decide to purchase a Netgate Global TAC Support subscription, you **MUST** have your **Netgate Device ID (NDI)** from your firewall in order to validate support for this unit. Write down your NDI and store it in a safe place. You can purchase TAC supports [here](#)."

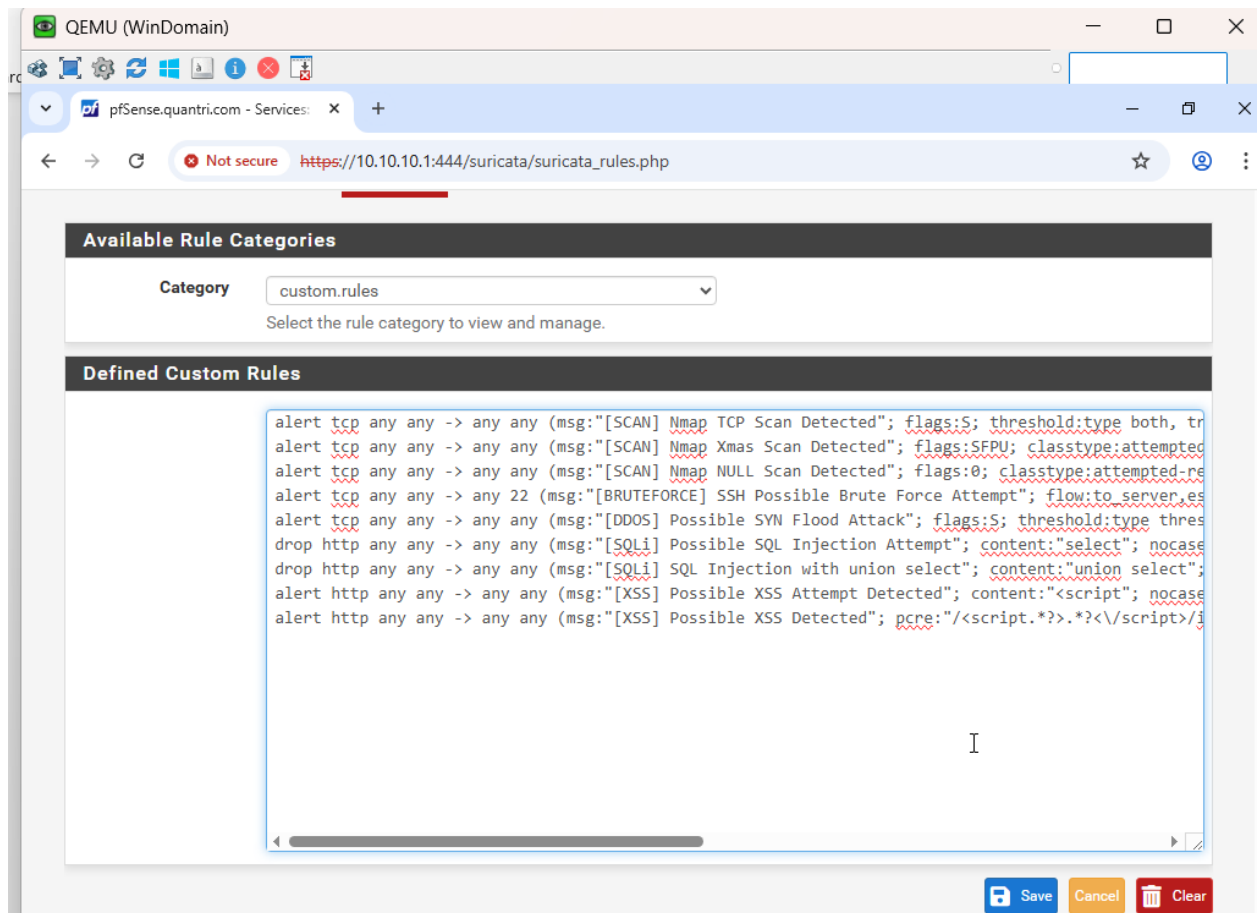
The footer of the interface states: "pfSense is developed and maintained by Netgate. © ESF 2004 - 2025 View license."

Khi bị tấn công



Ta có thể thấy cuộc tấn công đã làm cho cpu của tường lửa đang được đẩy cao lên(nếu đây là một cuộc tấn công mạng thực tế, số lượng máy có thể lên đến hàng trăm hàng ngàn, các server yếu sẽ không chịu nổi)

Bước 4: Ta bắt đầu cấu hình ips với các rule bằng suricata trên pfSense



Bước 5: xem alert và block trên suricata

QEMU (WinDomain)

pfSense.quantri.com - Services: x +

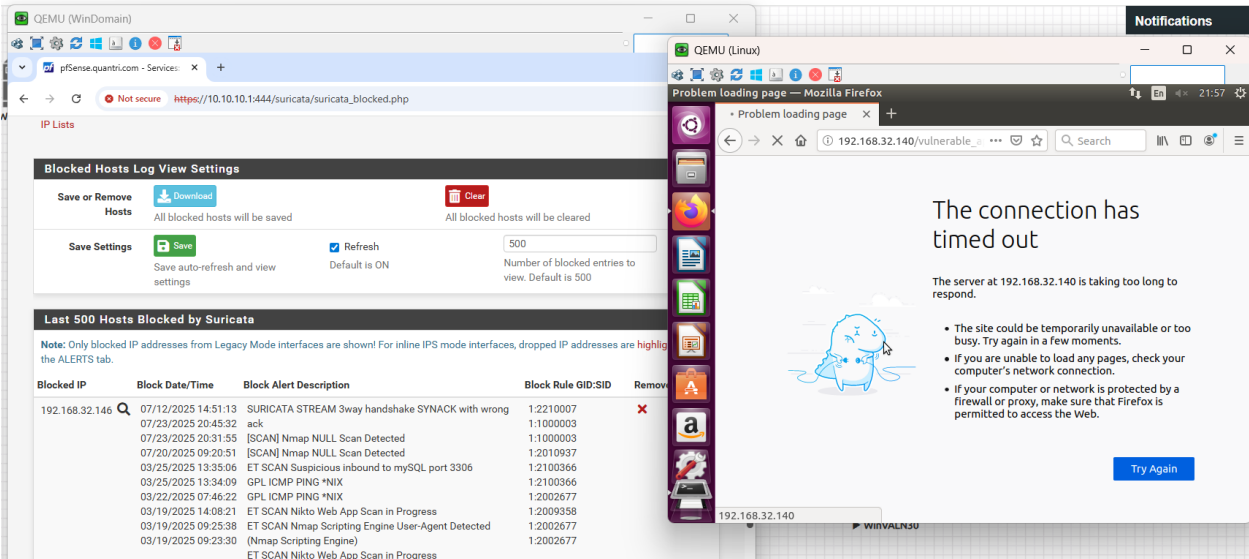
Not secure https://10.10.10.1:444/suricata/suricata_alerts.php

Alert Log View Filter +

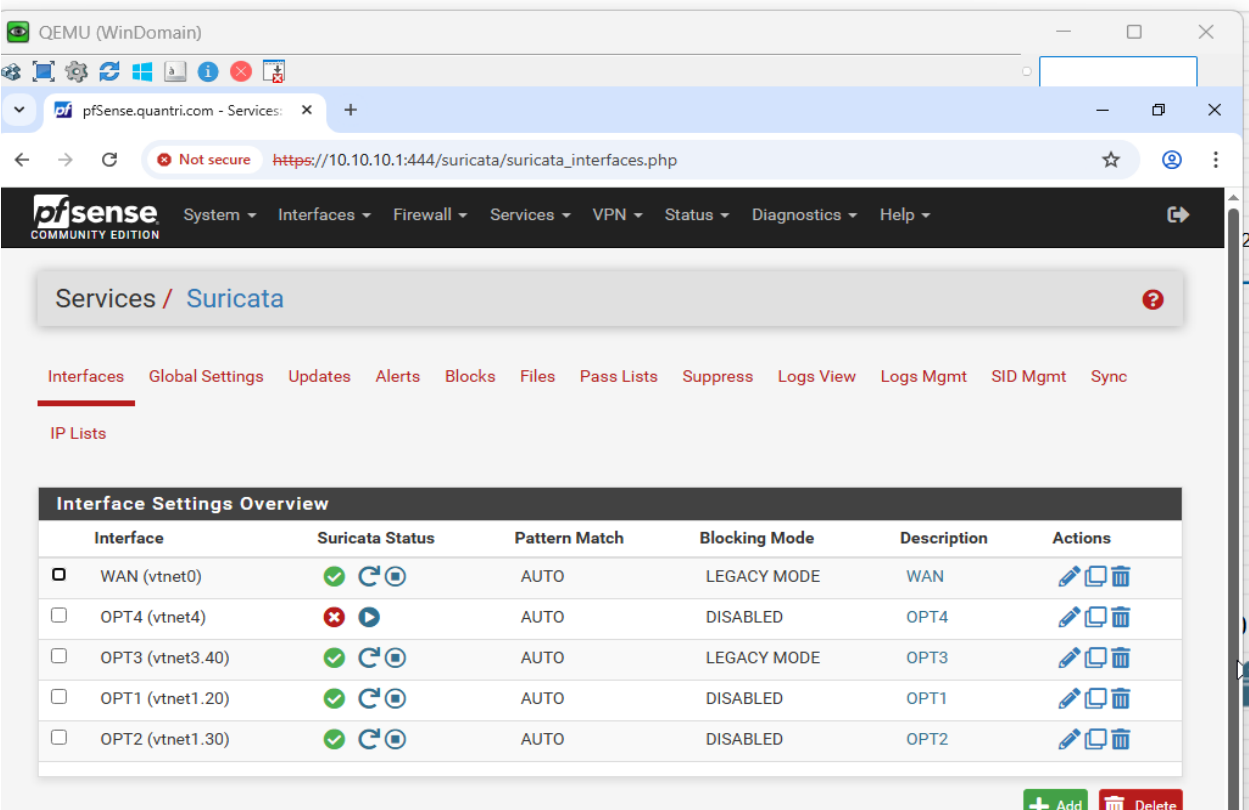
Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11092	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11091	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11090	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11089	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11086	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11083	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected
07/23/2025 20:48:13		2	TCP	Attempted Information Leak	192.168.32.146	11082	192.168.32.140	80	1:1000003	[SCAN] Nmap NULL Scan Detected

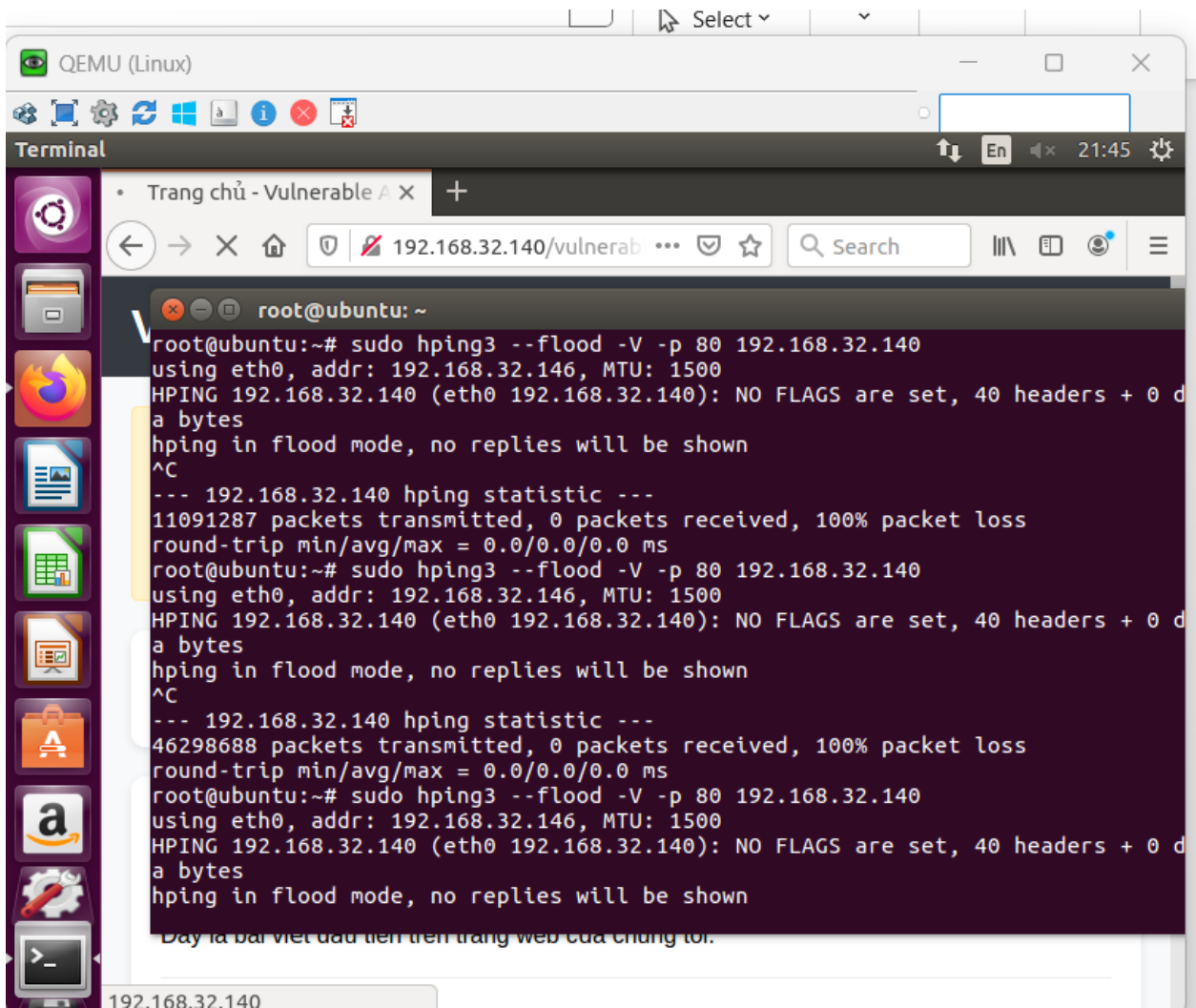
Bước 6: Trang web không thể truy cập được nữa



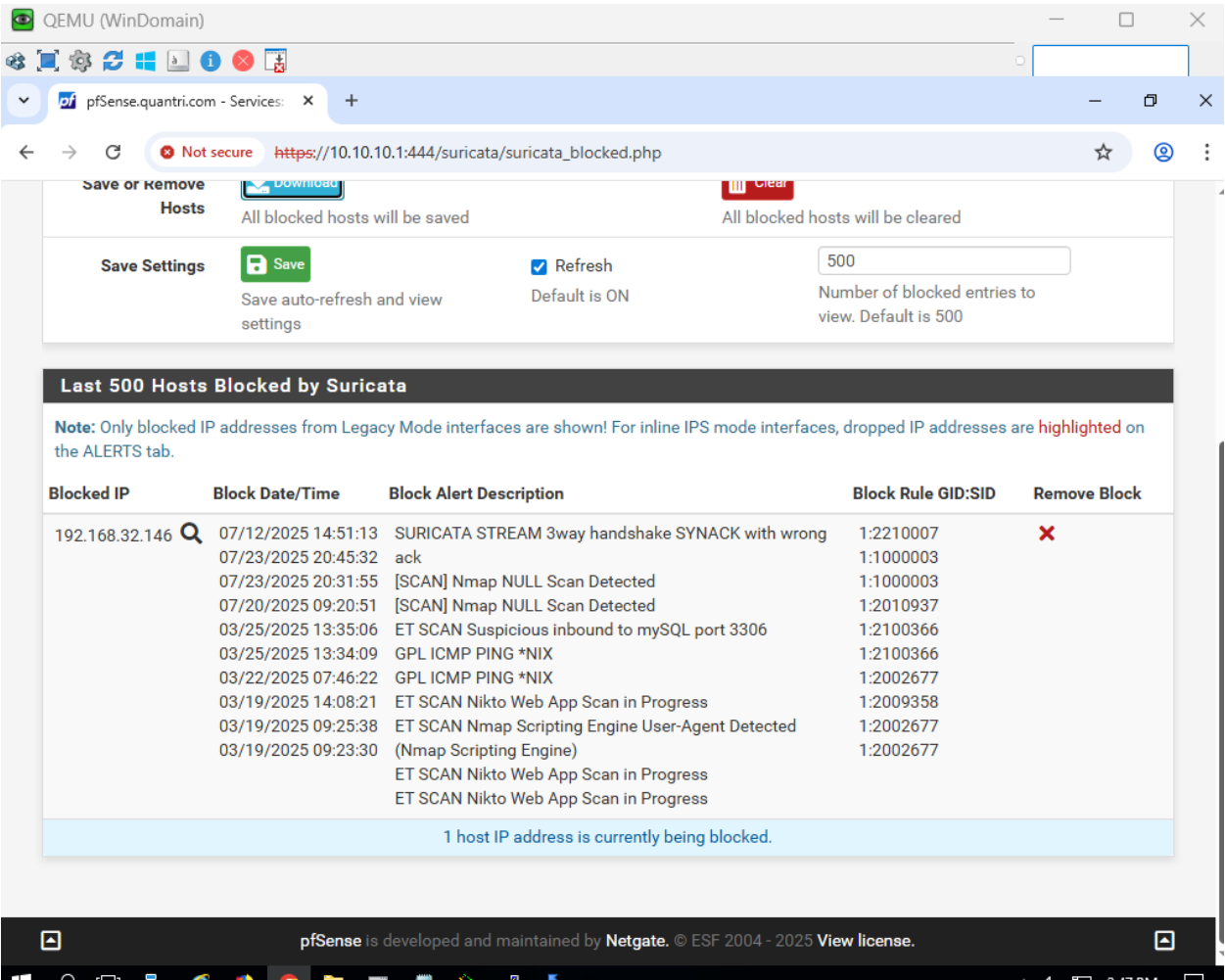
Bước 5: Khởi động giám sát



Bước 6: Hacker bắt đầu thử tấn công lại



Bước 7: Quay lại pfsense ta có thể thấy ip đã bị chặn



Bước 8: hacker không thể truy cập trang web được nữa

CHƯƠNG V TÀI LIỆU THAM KHẢO

<https://www.pfsense.org/getting-started/>

<https://docs.netgate.com/pfsense/en/latest/config/index.html>

https://youtu.be/7RhTJtF6Ab0?si=gbKW_TXkdI2yG_Ze

<https://youtu.be/m7ac0tPw7hQ?si=xykfWVRZhqh5kUr6>

<https://www.ossec.net/docs/docs/manual/agent/index.html>